

50 SOC INCIDENT RESPONSE PLAYBOOK

**BY IZZMIER
IZZUDDIN**

SOC Incident Response Playbook 1: Unauthorised SaaS OAuth Application Integration

Scenario

An employee or attacker grants a third-party application access to a corporate SaaS account using OAuth scopes (e.g., read email, access calendar, read/write files). These applications may exfiltrate data, impersonate users or maintain persistent access without triggering standard credential or MFA alerts.

Incident Classification

Category	Details
Incident Type	OAuth Abuse – Unauthorised Third-Party App
Severity	High (depending on the scopes granted and data accessed)
Priority	High to Critical
Detection Sources	CASB, SSPM, SaaS Admin Portals, SIEM, Threat Intelligence Feeds

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Restrict app consent policies	Only allow OAuth consent for pre-approved or verified apps
Monitor OAuth activity logs	Use SIEM or SaaS security tools to track app authorisations and scopes
Educate users	About risks of authorising personal or unknown apps in corporate environments
Integrate SSPM/CASP tools	For visibility into authorised applications and risk scoring
Apply conditional access policies	To limit app connections from unmanaged devices

2. Detection & Analysis

Step	Action
Alert triggered	Risky or unapproved OAuth app detected with elevated scopes (e.g., read mail, read drive, send messages)
Identify user and application	Who authorised it, what scopes were granted and what app was used
Analyse access logs	Check if app accessed sensitive data or performed actions (e.g., sending emails, downloading files)

Review app metadata	Reputation, risk score, domain registration, previous threat reports
MITRE ATT&CK mapping	T1528 (Steal Access Token), T1550.001 (Application Access Token), T1098.003 (External Account)

3. Containment

Step	Action
Revoke app access immediately	Via admin portal (e.g., Azure AD, Google Workspace, Slack admin)
Suspend impacted user account	If malicious behaviour or data leakage is confirmed
Block app domain or API endpoints	Via firewall, CASB or DNS filter to prevent callback connections
Notify user and security team	Initiate internal investigation and containment measures

4. Eradication

Step	Action
Remove residual access tokens	Revoke all tokens granted to the app and refresh user sessions
Rotate credentials and MFA	If impersonation or token theft is suspected
Conduct full data access review	Determine what the app had access to and if data was exfiltrated
Update OAuth policy	Add the app to a blocklist or blacklist category in SSPM or CASB

5. Recovery

Step	Action
Reinstate user access with monitoring	Ensure user awareness and endpoint clean-up if malware is linked
Apply stricter app review process	Require internal approval for all new app integrations
Monitor for recurrence	Create detections for similar app authorisation patterns or behaviours
Validate SaaS logs and alerts	Ensure full visibility of high-risk OAuth events

6. Lessons Learned & Reporting

Step	Action
------	--------

Complete root cause analysis	Why was the app authorised? Was it phishing, ignorance or bypassed control?
Improve user training	On secure SaaS usage and application access warnings
Strengthen OAuth governance	Integrate SSPM and automate risk-based app approval/revocation
Document the incident	For compliance, audit trails and policy updates
Notify affected parties or regulators	If customer data or sensitive records were accessed

Tools Typically Involved

- SSPM/CASP (e.g., AppOmni, Obsidian, Microsoft Defender for Cloud Apps)
- SaaS Admin Portals (e.g., Azure AD, Google Admin Console, Slack Admin)
- SIEM (e.g., Sentinel, Splunk)
- Threat Intelligence (for app risk scoring and reputation)
- SOAR (to automate detection and revocation)
- Endpoint Security (to ensure token origin is clean)

Success Metrics

Metric	Target
App Revocation Time	<15 minutes from detection
User Notification & Session Reset	<30 minutes
Full App Audit & RCA Completion	Within 48 hours
OAuth Policy Update	Within 3 business days
User Awareness Training Completion	100% within 5 business days

SOC Incident Response Playbook 2: CI/CD Supply Chain Poisoning via Compromised Base Images

Scenario

A developer or CI/CD system pulls a malicious or backdoored container base image (e.g., from Docker Hub, GitHub Packages, public artifact repositories) into a pipeline. This tainted image may contain cryptominers, reverse shells or logic bombs that affect build environments or production deployments.

Incident Classification

Category	Details
Incident Type	Supply Chain Compromise – Tainted CI/CD Artifacts
Severity	Critical
Priority	Critical
Detection Sources	CI/CD Logs, Artifact Scanners, CSPM, EDR, Threat Intelligence, Image Scanners (e.g., Trivy, Gype)

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Use trusted internal image registries	Prevent use of unknown or unauthorised public images
Scan all base images automatically	Use tools like Trivy, Gype, Aqua or Clair in CI pipelines
Maintain SBOM for all builds	Link image layers to dependency origins for traceability
Sign and verify container images	Use Cosign, Notary v2 or Sigstore for image integrity verification
Apply egress restrictions on runners	Prevent containers from initiating outbound connections by default

2. Detection & Analysis

Step	Action
Alert triggered	CI pipeline or image scanner detects malicious binary, network beaconing or unexpected process in base image
Identify affected pipelines or builds	Trace which projects, services or environments used the image
Analyse behaviour of container	Review runtime logs, network connections, system modifications

Cross-reference with threat intel	Check for known IOCs, CVEs or reported backdoored images
MITRE ATT&CK mapping	T1195.002 (Compromise Software Supply Chain), T1204.003 (Malicious File), T1105 (Ingress Tool Transfer)

3. Containment

Step	Action
Block further pulls of the compromised image	Remove access from all pipelines and registries
Disable affected pipelines or environments	Temporarily stop build and deploy operations for impacted apps
Revoke image caching	Remove local copies of tainted images from runners and registries
Notify DevOps, Security and App Owners	Coordinate immediate response actions

4. Eradication

Step	Action
Replace image with a trusted base	Rebuild services using a verified clean base image
Remove backdoors or injected tools	If deployed into test/staging/production, scan and clean infected containers
Update pipeline definitions	Reference only signed and vetted base images going forward
Rotate secrets and tokens	If compromised image had access to environment variables, keys or APIs

5. Recovery

Step	Action
Resume clean builds and deploys	After validation of base image security and CI/CD pipeline integrity
Validate systems that used the image	Ensure no persistence mechanisms or lateral movement occurred
Monitor for callback traffic	From prior deployments using the malicious image
Restore from clean backups	If persistent changes or damage was detected

6. Lessons Learned & Reporting

Step	Action
------	--------

Conduct RCA	Where was the malicious image introduced? How was it authorised?
Improve CI/CD governance	Enforce image signing, SBOM validation and approval workflows
Train development teams	On image provenance, trust boundaries and secure Dockerfile practices
Document incident	Include timelines, IOCs and preventive controls taken
Notify stakeholders or regulators	If breach involves sensitive data or production services

Tools Typically Involved

- Image Scanners (Trivy, Gype, Snyk, Clair)
- SBOM Tools (Syft, Anchore, CycloneDX)
- CI/CD Platforms (GitLab CI, GitHub Actions, Jenkins, Azure DevOps)
- Container Registries (Harbor, ECR, GCR, ACR)
- SIEM & SOAR (for alert correlation and response)
- Threat Intelligence Platforms (for IOC matching)

Success Metrics

Metric	Target
Detection to Block Time	<30 minutes from scan or alert
Pipeline Remediation Time	<4 hours
Secret Rotation Time	<24 hours for affected tokens and credentials
Signed Image Adoption Rate	≥ 95% of production services
Incident Report Completion	Within 3 business days

SOC Incident Response Playbook 3: Privilege Escalation via Misconfigured Cloud IAM Roles

Scenario

An attacker (external or insider) identifies and exploits misconfigured IAM roles, policies or trust relationships in cloud platforms (e.g., AWS, Azure, GCP) to escalate privileges. This can include lateral movement from a low-privilege identity to admin or service account roles, enabling full control over cloud resources.

Incident Classification

Category	Details
Incident Type	Privilege Escalation – Cloud IAM Misconfiguration
Severity	Critical
Priority	Critical
Detection Sources	CSPM, SIEM, Cloud Logs (e.g., CloudTrail, Azure Activity Logs), Identity Analytics, EDR/XDR

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enforce least privilege across IAM	Avoid wildcard * permissions, unused role chaining and overly permissive trust policies
Enable identity logging	Capture all role assumption events, token usage and privilege escalations
Use CSPM and IAM analyzers	Continuously scan for excessive permissions, unused roles or risky privilege paths
Segment high-privilege roles	Prevent broad access from service accounts or low-trust identities
Apply multi-factor authentication	To all privileged user accounts

2. Detection & Analysis

Step	Action
Alert triggered	Suspicious use of AssumeRole, token escalation or sudden privilege increase
Identify the source user or process	Determine the original identity and method used (CLI, API, web console)
Trace the escalation path	Map the IAM policy or trust chain that allowed the privilege elevation

Correlate with resource activity	Look for high-privilege actions post-escalation (e.g., key export, instance creation)
MITRE ATT&CK mapping	T1078.004 (Cloud Accounts), T1484.002 (Domain Trust Abuse), T1550.002 (Use of Cloud Instance Metadata API)

3. Containment

Step	Action
Disable affected IAM roles or policies	Immediately remove or update misconfigured trust relationships
Revoke temporary credentials	Invalidate session tokens or access keys that were abused
Limit service account access	If automation or machine identity was used for escalation
Notify cloud admin and security team	Coordinate rapid containment and remediation

4. Eradication

Step	Action
Audit and fix IAM misconfigurations	Remove over-permissive or unused roles and tighten trust policies
Rotate all potentially exposed credentials	Especially for accounts with escalation access
Validate cloud infrastructure integrity	Look for signs of tampering, persistence or lateral movement
Review identity federation settings	Ensure external IDPs or linked identities follow least privilege

5. Recovery

Step	Action
Restore normal IAM role mappings	After fixing misconfigurations and confirming safe usage
Re-enable workflows and automation	With updated permission boundaries and monitoring rules
Monitor activity of affected identities	Apply anomaly detection for the next 30 days
Apply tagging for sensitive roles	To enforce stricter review and approval processes

6. Lessons Learned & Reporting

Step	Action
------	--------

Conduct RCA	Determine how the escalation path was missed during design or review
Improve IAM review processes	Regular audits, change approvals and detection rules
Train cloud teams	On identity-based attack chains and permission boundaries
Update IAM policy templates	Enforce secure defaults and review workflows in Infrastructure-as-Code
Report incident	If it led to data exposure or regulatory risk (e.g., PDPA, ISO 27001)

Tools Typically Involved

- CSPM (e.g., Wiz, Prisma Cloud, Microsoft Defender for Cloud)
- IAM Analysis Tools (e.g., PMapper, IAM Access Analyzer, GCP Policy Analyzer)
- Cloud Logs (AWS CloudTrail, Azure Activity Logs, GCP Audit Logs)
- SIEM (e.g., Sentinel, Splunk, Chronicle)
- SOAR (for automated role revocation and credential rotation)
- Identity Governance (e.g., SailPoint, Saviynt)

Success Metrics

Metric	Target
Misconfigured Role Revocation	<15 minutes from detection
IAM Fix Deployment	<4 hours across impacted projects/accounts
High-Risk Role Review Completion	100% within 24 hours
Privilege Escalation Detections Tuned	Within 2 business days
RCA and Remediation Reporting	Within 72 hours

SOC Incident Response Playbook 4: Third-Party Vendor Compromise

Scenario

A security breach or malware infection occurs within a third-party vendor’s environment that has direct or indirect access to the organisation’s systems (e.g., via VPN, API, shared cloud environment, email communication or integration platform). The attacker may leverage this trust relationship to move laterally, steal data or deliver malicious payloads.

Incident Classification

Category	Details
Incident Type	Supply Chain / Vendor Compromise
Severity	High to Critical
Priority	Critical
Detection Sources	SIEM, Threat Intel Feeds, EDR, Identity Logs, Email Security, External Disclosure (e.g., vendor notification)

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Maintain third-party risk registry	Identify and rank vendors by access level and criticality
Use network segmentation and Zero Trust	Minimise vendor access scope
Monitor vendor accounts and integration logs	Include API usage, VPN activity, email metadata and file sharing logs
Enforce strict onboarding and offboarding	Review access regularly and revoke unused integrations or accounts
Establish incident response SLAs	Include third-party reporting requirements in contracts

2. Detection & Analysis

Step	Action
Alert triggered	Suspicious activity tied to vendor-controlled assets (e.g., VPN session, API call, email with malware)
Verify vendor access channels	Identify methods of access (VPN, API, SSH, SaaS integration) and their current usage
Correlate with internal indicators	Determine if lateral movement or data access occurred through the vendor’s access

Engage with vendor SOC or security team	Confirm breach details, timeline, IOCs and scope
MITRE ATT&CK mapping	T1195.002 (Compromise Software Supply Chain), T1133 (External Remote Services), T1203 (Exploitation of Remote Services)

3. Containment

Step	Action
Disable vendor access temporarily	VPN, API keys, user accounts, shared drives or federated identity
Block suspicious IPs or tokens	If access originated from known malicious infrastructure
Isolate any impacted internal systems	That were accessed or touched via vendor communication
Preserve and collect logs	Related to vendor access and internal system interaction

4. Eradication

Step	Action
Remove any malware or rogue code	Delivered through compromised vendor access or email
Rotate credentials used by the vendor	API keys, shared passwords, certificates or OAuth tokens
Patch exposed services or integrations	That may have been used for lateral access
Invalidate existing sessions	Related to the vendor's access

5. Recovery

Step	Action
Re-enable vendor access (if safe)	Only after vendor confirms full containment on their side
Apply enhanced monitoring	For high-risk vendor accounts for at least 30 days
Validate integrity of impacted systems	Check for configuration changes or backdoors
Resume operations	After full internal and vendor clearance

6. Lessons Learned & Reporting

Step	Action
------	--------

Conduct RCA	Understand entry point, detection delay and lateral movement path
Reassess vendor risk and trust level	Update risk registry and access privileges accordingly
Update contractual security clauses	If SLA, breach notification or audit rights were insufficient
Share IOCs and findings	Internally and with threat intel platforms if necessary
Report to regulators or clients	If customer data or systems were impacted

Tools Typically Involved

- SIEM (e.g., Splunk, Sentinel)
- Threat Intelligence Platforms (e.g., Recorded Future, MISP)
- EDR/XDR (e.g., CrowdStrike, Cortex XDR)
- Email Security Gateway (e.g., Proofpoint, Microsoft Defender)
- Network Monitoring (e.g., NDR, firewall logs)
- SOAR (for playbook automation and response)
- Vendor Risk Management Platform (e.g., OneTrust, BitSight)

Success Metrics

Metric	Target
Vendor Access Suspension Time	<15 minutes from detection
IOC Sharing with Vendor	Within 30 minutes
Third-Party RCA Participation	Within 24 hours
Credential Rotation Completion	<4 hours
Full System Review & Report	Within 3 business days

SOC Incident Response Playbook 5: API Abuse by Compromised Automation Scripts

Scenario

An attacker gains access to API keys or tokens used in automation scripts, build pipelines or cloud jobs. These secrets may be embedded in code, environment variables or CI/CD configuration files and can be exploited to perform unauthorised actions through APIs (e.g., data access, deletion, privilege abuse).

Incident Classification

Category	Details
Incident Type	Credential Misuse – API Abuse
Severity	High to Critical
Priority	Critical
Detection Sources	SIEM, Cloud Logs, WAF, API Gateway Logs, CI/CD Logs, Secret Scanners

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Store secrets securely	Use vaults (e.g., HashiCorp Vault, AWS Secrets Manager) instead of hardcoding
Rotate API tokens regularly	Enforce TTLs for short-lived tokens and automate rotation
Monitor API usage per key	Implement granular logging and usage monitoring for each token
Scan repositories and pipelines	Use tools like TruffleHog, Gitleaks, GitGuardian to detect exposed secrets
Apply rate limits and scope restrictions	Minimise token abuse impact by scoping API keys to specific actions

2. Detection & Analysis

Step	Action
Alert triggered	Abnormal API call pattern, burst traffic, data deletion or external access from automation token
Identify token and script source	Trace which job, service or script the compromised API key belongs to
Review recent script changes	Look for unauthorised modifications, token theft or external syncs

Correlate with access logs	Determine what data or systems were accessed or modified using the token
MITRE ATT&CK mapping	T1528 (Steal Access Token), T1110.003 (Brute Force: Password Spraying), T1552.001 (Credentials in Files)

3. Containment

Step	Action
Immediately revoke the compromised API key	At the platform or application level
Disable the affected script or job	To prevent further use until secured
Block attacker IPs or sessions	If abuse came from external networks
Isolate affected service account	And audit all associated activities and permissions

4. Eradication

Step	Action
Replace compromised tokens	Generate new tokens and store them securely in a vault
Clean exposed secrets from codebase	Purge commits with secrets from Git history (e.g., using BFG or git filter-branch)
Strengthen CI/CD secrets handling	Enforce secret injection via secure variables instead of plaintext
Patch any exploited systems or APIs	If abuse exploited a logic flaw or misconfiguration

5. Recovery

Step	Action
Resume secure automation jobs	After validation and secret reconfiguration
Monitor post-incident API usage	Track token replacements for abnormal behaviour
Verify system state and data integrity	Check for unauthorised changes or corruptions due to API abuse
Validate all tokens and credentials	In the affected namespace, repository or environment

6. Lessons Learned & Reporting

Step	Action
------	--------

Conduct RCA	How was the token exposed? What changes are needed in DevOps practices?
Update secure coding policies	Include rules on secret storage, access scopes and Git hygiene
Train developers and DevOps	On secure secret handling and pipeline hardening
Update API abuse detection rules	In SIEM, WAF and API gateways
Notify stakeholders or clients	If the abuse led to data exfiltration or business impact

Tools Typically Involved

- Secret Detection Tools (TruffleHog, Gitleaks, GitGuardian)
- CI/CD Platforms (GitHub Actions, GitLab CI, Jenkins)
- Secret Managers (AWS Secrets Manager, HashiCorp Vault, Azure Key Vault)
- API Gateways (Kong, Apigee, AWS API Gateway)
- SIEM (Splunk, Sentinel, Chronicle)
- EDR/XDR and SOAR (for script activity monitoring and response automation)

Success Metrics

Metric	Target
Token Revocation Time	<15 minutes from detection
Script/Job Disablement Time	<30 minutes
Credential Rotation Completion	<2 hours for affected services
Secrets Cleansing from Code Repos	<1 business day
Post-incident Audit & Report	Within 72 hours

SOC Incident Response Playbook 6: Persistent Access via Cloud Backdoor Accounts

Scenario

An attacker (or malicious insider) creates or retains hidden IAM users, service accounts or credentials within a cloud environment (e.g., AWS, Azure, GCP) to maintain persistence even after remediation of the initial incident. These accounts may be created under obscure names, embedded in automation or linked via federated identity.

Incident Classification

Category	Details
Incident Type	Persistence – Covert IAM Access
Severity	Critical
Priority	Critical
Detection Sources	CSPM, SIEM, IAM Audit Logs, CloudTrail, Identity Governance Tools, Threat Intelligence

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enable detailed IAM logging	Track all user/role creations, access keys, trust relationship updates
Enforce IAM review cycles	Periodically audit all cloud identities, including long-unused accounts
Use tags and naming standards	Identify legitimate vs suspicious accounts based on naming/owner metadata
Integrate identity lifecycle tools	Automate creation and de-provisioning with approval workflows
Monitor new account creation	Real-time alerting for new IAM users, roles or access keys

2. Detection & Analysis

Step	Action
Alert triggered	Unknown user/role/key detected performing actions or appearing in audit logs
Identify how the account was created	Via console, API, automation script or federated link
Check account age and usage	Determine if the account existed long before the alert or was recently added stealthily

Review activity logs	What has the backdoor account accessed, modified or created?
MITRE ATT&CK mapping	T1098 (Account Manipulation), T1078.004 (Cloud Accounts), T1556.004 (Cloud ID Manipulation)

3. Containment

Step	Action
Disable or delete the backdoor account	Immediately remove user, role or service principal
Revoke related credentials	API keys, tokens, sessions and certificates
Audit for lateral movement	Check if attacker used the backdoor to create more access pathways
Notify security leadership	Critical alert with potential long-term compromise indicators

4. Eradication

Step	Action
Review all IAM configurations	Identify and remove unused or risky roles, policies and trust relationships
Rotate keys and secrets	For all services that could have been accessed through the backdoor
Harden IAM policies	Block wildcard privileges, enforce trust boundaries and conditional access
Apply tighter federation controls	Ensure SSO/SAML/OIDC connections are scoped and monitored

5. Recovery

Step	Action
Restore IAM to validated state	Ensure all roles and users are approved, tagged and documented
Monitor for re-creation attempts	Alert on reappearance of similarly named or structured accounts
Enable Just-In-Time access (if possible)	Reduce standing privileges by enforcing approval-based access grants
Resume normal operations	Once IAM integrity is confirmed and access revalidated

6. Lessons Learned & Reporting

Step	Action
------	--------

Conduct RCA	Determine how the backdoor account was missed and what led to its creation
Strengthen account governance	Enforce stricter controls on IAM provisioning and lifecycle
Train cloud admins and DevOps	On IAM risks and naming hygiene, least privilege, audit trail review
Update cloud detection rules	For new user/role creation, abnormal access patterns and trust abuse
Report incident if data accessed	To internal stakeholders or regulators as required

Tools Typically Involved

- CSPM (e.g., Wiz, Prisma Cloud, Microsoft Defender for Cloud)
- IAM Analysis Tools (e.g., AWS IAM Access Analyzer, PMapper, GCP IAM Recommender)
- Cloud Audit Logs (e.g., AWS CloudTrail, Azure Activity Logs, GCP Admin Logs)
- Identity Governance (e.g., SailPoint, Saviynt)
- SIEM (e.g., Splunk, Sentinel)
- SOAR (for auto-remediation workflows)
- Threat Intelligence (for naming pattern or behaviour correlation)

Success Metrics

Metric	Target
Account Termination Time	<15 minutes from alert
Full IAM Audit Review	Within 24 hours
Secrets and Token Rotation	<4 hours
RCA Completion	Within 3 business days
Updated IAM Baseline Policies	Within 5 business days

SOC Incident Response Playbook 7: Unauthorised Access via Misconfigured Reverse Proxies

Scenario

An attacker exploits a misconfigured reverse proxy (e.g., Nginx, Apache, HAProxy, Cloudflare Tunnel, etc.) to gain access to protected internal services. This may include path traversal to internal APIs, bypassing authentication headers or proxying requests to sensitive resources (e.g., metadata endpoints, admin panels).

Incident Classification

Category	Details
Incident Type	Web Infrastructure Misconfiguration – Reverse Proxy Exploitation
Severity	High to Critical
Priority	High
Detection Sources	WAF Logs, Reverse Proxy Logs, SIEM, IDS/IPS, EDR, Threat Intelligence

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Review reverse proxy configs	Enforce proper access controls, path whitelisting and header validation
Deploy WAF and IPS in front of proxies	Detect and block suspicious or malformed HTTP requests
Harden authentication headers	Prevent header spoofing (X-Forwarded-For, X-Original-URL, etc.)
Segment internal services	Limit what can be reached via reverse proxy
Enable detailed proxy logging	Including full request path, headers and upstream destination

2. Detection & Analysis

Step	Action
Alert triggered	Proxy request to unauthorised path, unusual upstream calls or WAF rule hit
Review proxy access logs	Identify offending request patterns, headers, source IPs and targeted resources
Verify if auth bypass occurred	Check for access to /admin, /internal or metadata endpoints (/latest/meta-data)

Identify exposed services	Determine what internal apps were reachable via the proxy
MITRE ATT&CK mapping	T1133 (External Remote Services), T1071.001 (Web Protocols), T1190 (Exploit Public-Facing Application)

3. Containment

Step	Action
Disable affected proxy route or server block	Immediately stop access to the exposed path or subdomain
Block malicious IPs and request patterns	Through WAF, firewall or proxy-level filtering
Enable stricter access control rules	Require authentication on all paths, validate upstream headers
Notify web infra team	To begin configuration audit and rollback

4. Eradication

Step	Action
Fix proxy configuration	Apply strict path mappings, authentication enforcement and remove wildcard routes
Patch backend services	If accessed, ensure they are not vulnerable or misconfigured
Audit for persistence attempts	Look for shell uploads, command injection or beaconing from exposed apps
Regenerate credentials	If secrets or tokens were exposed via accessible URLs

5. Recovery

Step	Action
Test fixed proxy configuration	Validate against bypass attempts and confirm access control enforcement
Monitor exposed services	Apply enhanced logging and alerts for newly accessible endpoints
Resume normal access	Only after validation of full remediation and test passes
Communicate internally	Ensure all developers and operations teams are aware of the misconfiguration risks

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	Identify how the misconfiguration occurred (manual error, misaligned deployment, IaC bug)

Update DevOps processes	Enforce config reviews for reverse proxy changes and route additions
Train engineers	On secure reverse proxy patterns, header validation and zero trust enforcement
Document the incident	For audit trail, improvement plans and lessons learned tracking
Share IOCs and misconfiguration pattern	Internally and with peer teams to prevent recurrence

Tools Typically Involved

- Reverse Proxy (Nginx, HAProxy, Envoy, Apache, Cloudflare Tunnel)
- WAF/IPS (e.g., AWS WAF, ModSecurity, Palo Alto, Snort)
- SIEM (e.g., Splunk, Sentinel)
- EDR (e.g., CrowdStrike, Cortex XDR – if access reached workloads)
- Infrastructure-as-Code Review (e.g., Terraform, Ansible, Pulumi)
- Threat Intel Platform (for known proxy exploit patterns)

Success Metrics

Metric	Target
Misconfigured Path Disablement Time	<15 minutes from detection
Proxy Config Fix Deployment	<4 hours
Auth Bypass Verification Tests Passed	100% before recovery
DevOps Config Linting Enabled	Within 3 business days
RCA and Report Completion	Within 5 business days

SOC Incident Response Playbook 8: Man-in-the-Middle (MitM) in Hybrid Environments

Scenario

An attacker positions themselves between endpoints and backend systems (e.g., VPN gateway, database, SaaS interface) to eavesdrop, tamper with or redirect data. This can occur via rogue Wi-Fi, DNS spoofing, ARP poisoning, malicious proxies or compromised edge devices, especially in hybrid environments with complex routing.

Incident Classification

Category	Details
Incident Type	Network Interception – Man-in-the-Middle
Severity	Critical
Priority	Critical
Detection Sources	NDR, EDR/XDR, DNS Logs, Proxy Logs, VPN Logs, SIEM, User Reports

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enforce TLS 1.2+ everywhere	Ensure encryption for all internal and external traffic
Deploy NDR and SSL inspection	Detect anomalies in handshake behaviours and certificates
Apply DNS security controls	Enable DNSSEC, secure forwarders and internal DNS monitoring
Harden VPN configurations	Disable split tunnelling and enforce certificate-based authentication
Implement mutual TLS (mTLS)	Especially for sensitive microservices in hybrid architecture

2. Detection & Analysis

Step	Action
Alert triggered	Suspicious SSL certificate, duplicate IP/MAC behaviour or DNS poisoning indicators
Identify affected assets	Map out which endpoints, services or users are impacted
Correlate with network path	Determine whether traffic is being intercepted in transit (Wi-Fi, proxy, VPN gateway)

Extract MitM indicators	Unusual certificate issuers, dropped or altered packets, rogue DNS resolutions
MITRE ATT&CK mapping	T1557.002 (ARP Cache Poisoning), T1557.001 (LLMNR/NBT-NS Poisoning), T1040 (Network Sniffing), T1557.003 (DHCP Spoofing)

3. Containment

Step	Action
Isolate affected endpoint(s) or subnet	Immediately remove from network if compromise confirmed
Block rogue infrastructure	Using NAC, firewall rules and DNS filtering
Disable unverified proxy or split-tunnel VPN traffic	Force all traffic through secure gateways
Notify network and cloud teams	Begin network tracing and forensic packet capture

4. Eradication

Step	Action
Remove malicious proxy, rogue access point or poisoned route	Confirm through manual validation or network tools
Reconfigure trust anchors	Update CA stores and TLS pinning if certificates were spoofed
Reset VPN and proxy configurations	For users and services connected during the attack window
Patch affected devices or apps	If weaknesses allowed session hijacking or TLS downgrade

5. Recovery

Step	Action
Restore secure connectivity	Confirm route integrity, encrypted sessions and DNS correctness
Monitor impacted endpoints	For post-compromise behaviour or backdoors
Re-deploy compromised workloads	In clean environments with validated infrastructure paths
Resume operations	Only after verification of secure communication paths

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	Identify entry point: rogue DHCP, user error, outdated cert, device compromise

Enhance MitM detection capabilities	Strengthen NDR rules, alerting logic and SSL cert validation
Train staff	On Wi-Fi safety, VPN misuse and endpoint hygiene
Share insights with peers	Internally and externally (via ISAC, threat sharing alliances)
Document full incident	Include detection timeline, attack path, actions taken and prevention plan

Tools Typically Involved

- NDR (e.g., Corelight, Darktrace, ExtraHop)
- EDR/XDR (e.g., CrowdStrike, Cortex XDR)
- SIEM (e.g., Sentinel, Splunk)
- VPN and Proxy Logs (e.g., Zscaler, Fortinet, Palo Alto)
- Certificate Monitoring (e.g., Venafi, Censys, crt.sh feeds)
- DNS Security Tools (e.g., Infoblox, Quad9, Cisco Umbrella)
- Packet Capture (e.g., Zeek, Wireshark)

Success Metrics

Metric	Target
Endpoint Isolation Time	<10 minutes from alert
MitM Route Removal	<1 hour
TLS Reconfiguration and Testing	Completed within 24 hours
VPN and DNS Reinforcement	Within 2 business days
Full RCA and Remediation Report	Within 3 business days

SOC Incident Response Playbook 9: Session Hijacking via Token Replay

Scenario

An attacker captures a valid session token (e.g., JWT, OAuth, SAML, browser cookie) and reuses it to impersonate a legitimate user. This can occur through phishing, malware, man-in-the-middle (MitM) attacks, exposed tokens in code/repos or poorly secured local storage/session management.

Incident Classification

Category	Details
Incident Type	Credential/Session Theft – Token Replay
Severity	High
Priority	High
Detection Sources	SIEM, CASB, EDR, Cloud Logs (e.g., Azure AD, Google Workspace, Okta), Browser Telemetry, User Reports

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Use short-lived tokens with refresh flow	Enforce token TTLs and rotation
Bind sessions to user context	Device fingerprinting, IP range, browser metadata
Implement anomaly detection	Trigger alerts for session reuse from unusual geos or user agents
Secure session storage	Avoid placing tokens in local storage or URLs
Apply multi-factor authentication (MFA)	Especially for privileged actions

2. Detection & Analysis

Step	Action
Alert triggered	Same session/token used across multiple geolocations/devices or with impossible travel patterns
Analyse session metadata	IP address, location, user agent, timestamp and action performed
Correlate with user activity	Check whether the real user was active during the suspicious access
Validate token scope and use	Identify what services were accessed and if any data was modified or downloaded

MITRE ATT&CK mapping	T1539 (Steal Web Session Cookie), T1078 (Valid Accounts), T1550.004 (Web Session Cookie Reuse)
----------------------	--

3. Containment

Step	Action
Invalidate active session tokens	Force logouts for the affected user across all services
Block suspicious IPs or user agents	Using WAF, CASB or firewall rules
Lock user account temporarily	If compromise is confirmed or suspected
Notify user and security team	Initiate password reset and token invalidation procedures

4. Eradication

Step	Action
Reset user credentials and MFA tokens	If identity compromise is suspected
Remove malware or web skimmers	If token was stolen from the endpoint or browser
Patch affected apps	That expose tokens in URLs, logs or insecure cookies
Purge compromised access logs	To prevent attacker use of replayed tokens from archived data

5. Recovery

Step	Action
Re-enable user account	After re-authentication and endpoint validation
Monitor post-recovery activity	For suspicious behaviour or persistent threats
Review all affected services	For signs of lateral movement or abuse of elevated access
Resume user operations	Once full validation is complete

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	Identify how and where the token was leaked or intercepted
Enforce secure session design	Include token binding, CSRF protections and client-side storage review
Improve detection logic	For unusual session patterns, browser/user-agent mismatches

Train users	On phishing awareness and secure browser habits
Share IOCs internally	And externally if token theft was part of a campaign

Tools Typically Involved

- SIEM (Splunk, Sentinel, Chronicle)
- CASB/SSPM (Microsoft Defender for Cloud Apps, Netskope)
- Identity Providers (Azure AD, Okta, Google Workspace, Ping)
- Web App Firewalls (Cloudflare, Imperva, AWS WAF)
- EDR (Cortex XDR, CrowdStrike, SentinelOne)
- SOAR (for automated session revocation and alert correlation)

Success Metrics

Metric	Target
Session Invalidation Time	<15 minutes from detection
User Lock and Notification	Within 30 minutes
Token Replay Alert Coverage	100% of high-privilege users monitored
Credential & MFA Reset Completion	<4 hours
RCA and Mitigation Report	Within 3 business days

SOC Incident Response Playbook 10: Lateral Movement from SaaS to On-Prem via Federated Identity

Scenario

An attacker compromises a cloud/SaaS account (e.g., Microsoft 365, Google Workspace, Okta, Salesforce) and uses identity federation (e.g., SAML, OAuth, SCIM) to gain access to on-premise resources like VPNs, legacy apps, file shares or domain-joined systems. This type of lateral movement exploits the trust relationship between identity providers (IdPs) and service providers (SPs).

Incident Classification

Category	Details
Incident Type	Identity Federation Exploitation – Lateral Movement
Severity	Critical
Priority	Critical
Detection Sources	SIEM, Identity Logs (Azure AD, Okta, etc.), VPN Logs, EDR, LDAP Logs, On-Prem Authentication Logs

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enforce conditional access policies	Apply geolocation, device and risk-based restrictions
Use MFA for federated accounts	Especially for high-privilege and hybrid access users
Log federation events across environments	Track logins, token issuance and SAML assertions
Limit federation scope	Only allow federation for necessary services or groups
Audit IdP-SP configurations	Detect over-permissive role mappings and misaligned trust settings

2. Detection & Analysis

Step	Action
Alert triggered	Unusual login from federated SaaS account into on-premise service (e.g., VPN, RDP, legacy app)
Analyse login path	Determine if lateral movement occurred through SAML assertions, SCIM sync or OAuth token forwarding

Check for device and IP anomalies	Identify mismatches between device posture and access level granted
Review directory sync logs	Identify whether user groups, attributes or roles were manipulated
MITRE ATT&CK mapping	T1078.004 (Cloud Accounts), T1550.002 (Use of Cloud Identity Federation), T1071.001 (Web Protocols)

3. Containment

Step	Action
Disable federated identity access	Temporarily block the affected account or federation trust path
Invalidate sessions and tokens	Revoke SAML assertions, OAuth tokens and refresh tokens
Restrict on-prem access via firewall or ACLs	Block federated users from internal segments during investigation
Notify identity, cloud and infra teams	Coordinate rapid access control updates

4. Eradication

Step	Action
Reset credentials and MFA	For compromised federated accounts
Correct federation mappings	Remove or adjust risky role mappings, attribute assertions and SSO integrations
Remove any sync manipulation	Roll back malicious SCIM provisioning or directory sync changes
Patch federation infrastructure	Apply latest security updates for IdPs, SSO brokers and sync agents

5. Recovery

Step	Action
Restore federation connectivity	After all trust and role assertions are validated and hardened
Re-enable user access	After credentials are reset and device posture confirmed
Monitor for re-pivot attempts	Set up SIEM rules and behaviour analytics for hybrid identity access
Resume production operations	After security validation and cleanup

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	Determine how the federation channel was abused (token theft, role misconfiguration, SCIM misuse)
Harden identity federation policy	Require stronger verification on trust relationships and dynamic provisioning
Train admins	On secure federation design, SSO security and sync monitoring
Document the incident	Timeline, access scope, root cause and response efforts
Share findings	Internally and with identity platform vendors if bugs or gaps contributed

Tools Typically Involved

- Identity Providers (e.g., Azure AD, Okta, Ping Identity, ADFS)
- SIEM (e.g., Splunk, Sentinel, LogRhythm)
- EDR/XDR (e.g., CrowdStrike, Cortex XDR)
- VPN and Authentication Logs (e.g., RADIUS, LDAP, Kerberos)
- Cloud Logging Tools (e.g., Microsoft 365 Audit Logs, Google Workspace Admin Logs)
- SCIM Directory Sync Logs (e.g., Okta UD, Azure AD Connect)

Success Metrics

Metric	Target
Account Lock Time	<10 minutes from detection
Federation Mapping Review Completion	<4 hours
Credential & Role Remediation	<1 business day
RCA Report Submission	Within 72 hours
SIEM Rule Update & Tuning	Within 5 business days

SOC Incident Response Playbook 11: Data Exfiltration via Encrypted DNS Tunnels (DoH/DoT)

Scenario

An attacker uses encrypted DNS tunnelling (e.g., DoH or DoT) to exfiltrate sensitive data from compromised endpoints. These methods encrypt DNS queries and responses, making it harder for traditional DNS monitoring solutions to detect command-and-control (C2) or data exfiltration channels.

Incident Classification

Category	Details
Incident Type	Covert Exfiltration – Encrypted DNS Tunnel
Severity	High
Priority	High
Detection Sources	NDR, EDR/XDR, DNS Proxy Logs, TLS Fingerprinting, Threat Intelligence, SIEM

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Block unauthorised DoH/DoT resolvers	Enforce DNS resolution through enterprise DNS servers only
Deploy TLS fingerprinting (JA3/JA3S)	Detect unique signatures of known tunnelling tools
Monitor for known DoH providers	Such as Cloudflare, Google and Mozilla over non-standard ports
Use EDR and NDR tools	To inspect outbound encrypted traffic and detect tunnelling behaviour
Enable egress controls	Prevent non-approved ports (443, 853) from reaching public DNS resolvers

2. Detection & Analysis

Step	Action
Alert triggered	High volume of DoH/DoT traffic from non-browser processes or unknown endpoints
Analyse JA3/JA3S hashes	Match TLS fingerprints with known tunnelling tools (e.g., iodine, dns2tcp, dnscat2)
Identify endpoint process	Determine which application or script initiated the encrypted DNS traffic

Review data volume and frequency	Look for tunnelling patterns such as periodic bursts or encoded payloads
MITRE ATT&CK mapping	T1071.004 (Application Layer Protocol: DNS), T1048 (Exfiltration Over Alternative Protocol), T1090.003 (Multi-Stage Channels)

3. Containment

Step	Action
Isolate the affected endpoint	Remove from the network to stop ongoing exfiltration
Block specific DoH/DoT endpoints	At firewall or proxy level using domain and IP filtering
Disable outbound DNS to unauthorised servers	Enforce policy-based DNS routing
Notify relevant SOC and network teams	Begin wider traffic inspection across similar assets

4. Eradication

Step	Action
Remove tunnelling malware or scripts	From infected endpoint(s) after full forensic review
Patch system vulnerabilities	That allowed malware to establish persistence or outbound comms
Reimage if persistence mechanisms are confirmed	Especially in high-impact environments
Rotate credentials and revoke tokens	If any were exposed or exfiltrated through the tunnel

5. Recovery

Step	Action
Restore endpoint connectivity	After full validation of threat removal and secure configuration
Resume normal DNS resolution	Through enterprise-approved servers with inspection enabled
Monitor endpoint post-recovery	For beaconing, process anomalies or re-exfiltration attempts
Review access logs for data leakage	Determine what information may have been exposed

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	Identify how tunnelling tool was deployed and evaded detection
Improve DNS monitoring policies	Include encrypted DNS inspection and usage analytics
Update SIEM/NDR detection logic	For encrypted tunnels, JA3 signatures and high-entropy DNS traffic
Train staff	On recognising covert tunnelling behaviours and suspicious process activity
Report if sensitive data left the organisation	Based on regulatory or contractual obligations

Tools Typically Involved

- NDR (e.g., Corelight, Vectra, ExtraHop)
- EDR/XDR (e.g., CrowdStrike, Cortex XDR, Microsoft Defender ATP)
- DNS Monitoring Platforms (e.g., Infoblox, Cisco Umbrella)
- SIEM (e.g., Splunk, Sentinel)
- TLS/JA3 Analytics Tools (e.g., Zeek, SecurityOnion, ELK Stack)
- Firewall/Proxy (e.g., Palo Alto NGFW, Zscaler, Fortinet)

Success Metrics

Metric	Target
Endpoint Isolation Time	<10 minutes from detection
Traffic Block Time	<30 minutes for targeted DoH/DoT endpoints
Malware Eradication & Verification	Within 1 business day
SIEM/NDR Detection Rule Update	Within 2 business days
RCA and Compliance Report	Within 3 business days

SOC Incident Response Playbook 12: Business Email Compromise via OAuth App Abuse

Scenario

An attacker tricks a user into authorising a malicious OAuth application (e.g., via phishing or fake login portals), which then gains API-level access to read emails, send messages or access OneDrive/SharePoint, all without needing credentials. This bypasses traditional MFA and login detection.

Incident Classification

Category	Details
Incident Type	Business Email Compromise – OAuth Token Abuse
Severity	Critical
Priority	Critical
Detection Sources	Microsoft 365 Audit Logs, Google Workspace Logs, CASB, SIEM, Identity Provider Logs (Azure AD, Okta)

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Restrict third-party OAuth apps	Only allow pre-approved or consented apps for enterprise users
Enable OAuth app governance	Via Defender for Cloud Apps (CASB), Google Workspace Admin or Okta
Audit app permission grants	Alert on excessive scopes (e.g., Mail.ReadWrite, Files.Read.All)
Monitor consent activities	Log and alert on new OAuth approvals, especially from non-admin users
Train users	On phishing, app consent warnings and OAuth risks

2. Detection & Analysis

Step	Action
Alert triggered	OAuth app registered with risky scopes or user behaviour anomaly in email activity
Identify affected user and app	Use audit logs to trace consent timestamp, scopes granted and app ID
Review API access logs	Look for malicious read/send actions (e.g., forwarding rules, internal recon, exfiltration)

Correlate with known campaigns	Match app names or behaviours to known APT groups (e.g., consent phishing kits)
MITRE ATT&CK mapping	T1528 (Steal Access Token), T1078.004 (Cloud Accounts), T1550.003 (OAuth Token Abuse)

3. Containment

Step	Action
Revoke the malicious app's token	Via identity provider or Microsoft 365 security portal
Disable affected account temporarily	If malicious actions are confirmed
Block app registration (App ID, publisher)	At tenant-wide level via admin policies
Notify user and SOC team	Begin account hardening and investigation

4. Eradication

Step	Action
Remove persistence mechanisms	Delete forwarding rules, inbox rules and sharing links created by the app
Reset OAuth tokens and refresh credentials	Invalidate all active authorisations for the user
Harden tenant-wide OAuth policies	Block user consent for risky scopes or external apps
Investigate lateral phishing attempts	If attacker sent internal messages or links

5. Recovery

Step	Action
Restore account access	After confirming account integrity and revoking malicious access
Reinstate legitimate apps	Reconnect necessary services after re-approval through secured processes
Monitor account post-recovery	Enhanced logging and alerts for 14–30 days
Validate impact scope	Assess whether sensitive emails or files were accessed or forwarded

6. Lessons Learned & Reporting

Step	Action
------	--------

Conduct RCA	Identify how the app was authorised and if multiple users were affected
Improve OAuth hygiene	Enforce tighter controls on app registration and consent processes
Train users and admins	On identifying fake app pop-ups and consent phishing attacks
Update SIEM and CASB rules	For new risky OAuth app behaviours or known malicious publisher IDs
Report breach if sensitive data was accessed	Follow local compliance (e.g., PDPA, GDPR, HIPAA)

Tools Typically Involved

- Microsoft Defender for Cloud Apps (CASB)
- Microsoft 365 Security & Compliance Center
- Google Workspace Admin Console
- Okta or Azure AD Logs
- SIEM (Sentinel, Splunk)
- Identity Threat Detection & Response (e.g., Proofpoint, Abnormal Security)

Success Metrics

Metric	Target
Malicious App Revocation Time	<30 minutes from detection
User Notification and Lock	<1 hour
Token and Rule Cleanup	<4 hours
OAuth Policy Update Completion	Within 2 business days
RCA and Reporting	Within 3 business days

SOC Incident Response Playbook 13: Destructive Malware in Hybrid Active Directory Environments

Scenario

A destructive malware attack (e.g., wiper, ransomware with kill-switch or NotPetya-style attack) impacts both on-premise AD and Azure AD-integrated environments, aiming to cause maximum disruption by disabling domain controllers, corrupting authentication systems, encrypting GPOs or deleting critical files.

Incident Classification

Category	Details
Incident Type	Destructive Malware – Hybrid AD Impact
Severity	Critical
Priority	Urgent
Detection Sources	EDR/XDR, SIEM, Domain Controller Logs, DNS Logs, Azure AD Logs, Threat Intel Feeds

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Isolate and monitor critical DCs	Apply strict segmentation and behavioural monitoring
Backup AD and Azure AD configurations	Securely and regularly back up domain controllers and GPOs
Deploy tamper-proof EDR on domain controllers	Ensure visibility and rollback options
Harden AD with Tiered Admin Model	Separate duties and use privileged access workstations (PAWs)
Test restore processes	Simulate AD corruption scenarios regularly

2. Detection & Analysis

Step	Action
Alert triggered	Sudden shutdown of DCs, GPO deletion, mass file encryption or process tampering on critical systems
Identify initial access vector	Phishing, RDP brute force, misused credentials or software supply chain
Trace malware propagation	Review lateral movement paths, PsExec use, SMB or WMI remoting

Correlate with known threat signatures	Match binaries or behaviours to known destructive malware (e.g., HermeticWiper, NotPetya, ZeroCleare)
MITRE ATT&CK mapping	T1485 (Data Destruction), T1486 (Data Encrypted for Impact), T1489 (Service Stop), T1078 (Valid Accounts), T1021.002 (SMB/Windows Admin Shares)

3. Containment

Step	Action
Disconnect infected hosts	Immediately isolate affected endpoints, especially domain controllers
Disable compromised accounts	Including any with replication rights or admin privileges
Quarantine affected VLANs	To prevent cross-segment propagation
Block C2 and lateral traffic	Update firewall, EDR and NDR signatures

4. Eradication

Step	Action
Remove malware binaries and persistence mechanisms	Clean up scheduled tasks, registry entries and startup folders
Rebuild destroyed systems	From clean backups, starting with DCs and critical infrastructure
Patch exploited vulnerabilities	Across all endpoints involved in initial access or escalation
Clean domain trust relationships	Check for rogue domain joins or tampered replication

5. Recovery

Step	Action
Restore AD and DNS from verified backups	Test integrity before bringing online
Reconnect systems in phases	Validate clean state and behaviour
Re-enable identity federation	Only after ensuring no token or key material was leaked
Monitor for re-infection or data leakage	Use SIEM/EDR/NDR for early detection

6. Lessons Learned & Reporting

Step	Action
Conduct full RCA	Include attack path, security gaps and delay factors

Enhance segmentation and least privilege	Especially in hybrid identity systems
Update incident playbooks and backups	With gaps discovered during the attack
Train blue team and AD admins	On specific destructive malware behaviours and response techniques
Report to relevant authorities	If data destruction impacts critical operations or customers

Tools Typically Involved

- EDR/XDR (CrowdStrike, Cortex XDR, Defender for Endpoint)
- SIEM (Splunk, Sentinel, QRadar)
- AD Monitoring (e.g., BloodHound, Purple Knight, ADAudit Plus)
- Azure AD Logs & Conditional Access Reports
- DNS Monitoring (e.g., Corelight, Zeek)
- Immutable Backup Tools (e.g., Veeam, Rubrik, Cohesity with ransomware protection)

Success Metrics

Metric	Target
DC Isolation Time	<10 minutes from detection
Malware Eradication	<24 hours for root-cause systems
AD Restore and Integrity Checks	Within 4 hours of containment
RCA and Postmortem Delivery	Within 3 business days
Long-Term Controls Applied	Within 7 business days

SOC Incident Response Playbook 14: Ransomware Targeting Cloud Storage Buckets

Scenario

An attacker gains access to a cloud account with privileges to manage storage buckets (e.g., Amazon S3, Azure Blob, GCP Cloud Storage). They encrypt, overwrite or delete files or apply ransomware tactics via scripting tools (e.g., AWS CLI) to demand payment in exchange for decryption keys or backups.

Incident Classification

Category	Details
Incident Type	Ransomware – Cloud Storage Compromise
Severity	Critical
Priority	Critical
Detection Sources	CloudTrail (AWS), Azure Activity Logs, GCP Audit Logs, SIEM, CASB, Threat Intel, Backup Alerts

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enable versioning & object lock	On cloud buckets to protect against deletion and unauthorised overwrites
Use least privilege IAM roles	Avoid giving s3:DeleteObject or storage.objects.delete to all users
Monitor cloud storage APIs	Alert on bulk operations (PUT, DELETE, COPY) or anomalies in access patterns
Back up storage buckets regularly	And store backups in isolated accounts or vaults
Restrict programmatic access	Block unnecessary API keys and enforce temporary credentials

2. Detection & Analysis

Step	Action
Alert triggered	Bulk deletion or encryption-like write patterns detected from user/API
Identify affected buckets	Check logs for timestamps, user agents, IPs and modified file paths
Investigate access vector	Was access via leaked credentials, compromised IAM role or OAuth token?

Examine impacted data	Assess if files were encrypted, renamed or deleted
MITRE ATT&CK mapping	T1486 (Data Encrypted for Impact), T1530 (Data from Cloud Storage Object), T1203 (Exploitation for Client Execution – e.g., script abuse)

3. Containment

Step	Action
Revoke credentials or API keys	Disable access to prevent further write/delete actions
Detach risky IAM policies	Remove affected role's access to sensitive buckets immediately
Quarantine account/session	Use identity provider controls or cloud quarantine functions
Block malicious IPs or automation tools	Using firewall rules or token expiry

4. Eradication

Step	Action
Remove rogue scripts, users or automation jobs	Check for scheduled tasks or compromised pipelines
Investigate lateral movement	Look for compromised IAM roles or tokens across services
Patch IAM misconfigurations	Harden trust relationships and eliminate broad write permissions
Reconfigure API access controls	Enforce MFA and conditional access on all cloud accounts

5. Recovery

Step	Action
Restore from clean backups or object versions	Use versioning or offsite backups stored securely
Validate restored data integrity	Run file hash checks, audit access and verify content accuracy
Re-enable operations with hardened access	Re-grant permissions only after validation and hardening steps
Implement cloud DLP/monitoring	Continue to monitor bucket access for anomalies

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	Determine how the attacker gained access and why controls failed
Enforce better segmentation	Separate production, staging and backup storage by IAM boundary
Train DevOps teams	On proper permission scoping, key rotation and API auditing
Update incident response plans	To reflect cloud-native ransomware response improvements
Report incident as necessary	Especially if customer data was encrypted or deleted

Tools Typically Involved

- AWS CloudTrail / Azure Monitor / GCP Logging
- SIEM (e.g., Splunk, Sentinel, Chronicle)
- Cloud Security Posture Management (e.g., Prisma Cloud, Wiz orca)
- Backup & DR Solutions (e.g., AWS Backup, Veeam, Rubrik, Azure Recovery Vault)
- Identity Providers (e.g., Azure AD, Okta, IAM roles/policies)
- Threat Intelligence Platforms (for known ransomware tools/APIs)

Success Metrics

Metric	Target
Bucket Access Revocation Time	<15 minutes from detection
Backup Restore Time	<4 hours for critical data
IAM Policy Review Completion	<1 business day
RCA Finalisation and Controls Updated	Within 3 business days
Detection Coverage (Write/Delete Events)	≥ 95% of critical buckets monitored

SOC Incident Response Playbook 15: Insider Data Theft via Unmanaged Personal Cloud Apps

Scenario

An employee uploads confidential or sensitive files (e.g., customer data, intellectual property, financial reports) to their personal cloud storage accounts. This may be intentional (malicious insider) or accidental (negligent user), often occurring via browser uploads, sync tools or shadow IT apps not controlled by the organisation.

Incident Classification

Category	Details
Incident Type	Insider Threat – Unauthorised Data Exfiltration
Severity	High
Priority	High
Detection Sources	CASB, DLP, Proxy Logs, EDR, SIEM, UEBA, Endpoint Monitoring, Shadow IT Discovery Tools

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Deploy CASB or inline proxy	Detect and block uploads to personal cloud storage domains
Use Endpoint DLP	To monitor clipboard, USB, print and browser-based file transfers
Enforce allowlists	Only permit corporate-approved cloud storage apps on managed endpoints
Monitor browser activity	Through proxy or agent-based tools for suspicious file upload behaviour
Train employees	On data classification policies and cloud storage risks

2. Detection & Analysis

Step	Action
Alert triggered	File upload detected to a domain associated with personal cloud apps (e.g., drive.google.com, dropboxusercontent.com)
Identify the user and host	Map network or endpoint logs to specific user, device and location
Analyse file metadata	Check for sensitivity labels, document titles, classification, size and upload method

Determine intent	Was it part of work activity, negligence or deliberate exfiltration?
MITRE ATT&CK mapping	T1041 (Exfiltration Over C2 Channel), T1537 (Transfer Data to Cloud Account), T1081 (Credentials in Files)

3. Containment

Step	Action
Isolate or monitor the user session	Depending on severity and insider policy (e.g., soft lock, silent logging)
Block access to target cloud domains	Via proxy, firewall or CASB
Revoke sync tool authorisations	If installed or configured on endpoint (e.g., Dropbox client)
Alert insider risk or HR team	For joint investigation and potential legal follow-up

4. Eradication

Step	Action
Remove unauthorised tools	From user workstation (e.g., remove browser extensions, sync clients)
Disable browser access	To known unsanctioned cloud storage services via proxy policy
Recover exfiltrated data if possible	Request takedown via legal or use cloud app API (if under enterprise visibility)
Rotate exposed credentials	If sensitive files contained passwords, secrets or keys

5. Recovery

Step	Action
Re-enable system access	After verifying system is clean and user access restrictions are appropriate
Enforce strict usage policies	Require future uploads to go through DLP gateways or sanctioned apps only
Reinforce employee awareness	Conduct targeted security awareness for user/team involved
Monitor user post-incident	Under increased scrutiny for signs of repeat behaviour

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	Why was unsanctioned upload possible (tool misconfig, DLP bypass, policy gap)?

Tune detection rules	For new upload behaviours, domains and endpoints
Review insider threat program	Update thresholds, response procedures and escalation matrix
Document the full incident	Including user intent, data scope, tools used and resolution steps
Notify data owners and legal	Especially if regulated data or trade secrets were involved

Tools Typically Involved

- CASB (e.g., Microsoft Defender for Cloud Apps, Netskope, Skyhigh)
- DLP (Symantec, Forcepoint, Microsoft Purview DLP)
- EDR/XDR (Cortex XDR, CrowdStrike, SentinelOne)
- Proxy/NGFW Logs (e.g., Zscaler, Palo Alto, Blue Coat)
- SIEM (Splunk, Sentinel, QRadar)
- Insider Risk Management (e.g., Microsoft Purview IRM, Proofpoint ITM)

Success Metrics

Metric	Target
Upload Detection to Containment Time	<15 minutes
User Investigation and Resolution	<4 hours
Full RCA Completion	<3 business days
CASB/DLP Policy Update	Within 2 business days
Repeat Offence Rate (Post-Awareness)	<1% over 90 days

SOC Incident Response Playbook 16: Supply Chain Compromise via Third-Party Software Updates

Scenario

A trusted software vendor is compromised and attackers inject malicious code into legitimate software updates (e.g., MSI, EXE, script, DLL). The malware is distributed automatically via update channels or download links, affecting multiple endpoints in the organisation. Examples include SolarWinds Orion, CCleaner and Kaseya.

Incident Classification

Category	Details
Incident Type	Supply Chain – Software Update Backdoor
Severity	Critical
Priority	Urgent
Detection Sources	EDR/XDR, SIEM, Threat Intelligence, Endpoint Logs, File Integrity Monitoring, Vendor Alerts

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Maintain SBOM (Software Bill of Materials)	Track all third-party tools, dependencies and update paths
Implement allowlisting	Only permit software execution from trusted sources and code-signed binaries
Monitor vendor advisory feeds	Subscribe to threat intelligence and vendor incident feeds
Test updates in sandbox environments	Before deployment to production
Enable behavioural detection	Detect suspicious post-installation activity regardless of vendor trust

2. Detection & Analysis

Step	Action
Alert triggered	Post-update execution anomaly: unusual process, external communication or persistence mechanism
Identify affected software	Verify software name, version, vendor and deployment scope
Correlate indicators	Hashes, C2 domains, file paths, lateral movement or privilege escalation behaviour

Validate with vendor notices	Confirm if update has known compromise or matches reported campaigns
MITRE ATT&CK mapping	T1195.002 (Supply Chain Compromise – Compromise Software Supply Chain), T1059 (Command & Scripting), T1218 (Signed Binary Proxy Execution)

3. Containment

Step	Action
Isolate affected hosts	Prioritise endpoints that installed the compromised update
Block update package hashes and file paths	Prevent further execution or propagation
Disable automated updates	Temporarily halt update processes for the specific vendor/software
Notify vendor and internal stakeholders	Initiate legal, compliance and partner comms if needed

4. Eradication

Step	Action
Remove backdoored components	Use EDR to identify and remove persistence mechanisms, trojans or altered binaries
Replace with clean software versions	Deploy verified versions of the application after vetting
Rotate credentials and tokens	If affected software had access to sensitive environments or APIs
Clean infected registry, scheduled tasks or services	Associated with post-compromise malware execution

5. Recovery

Step	Action
Restore systems from trusted backups	For high-risk hosts if system integrity is uncertain
Re-enable trusted update channels	Only after full validation of the new versions
Reassess third-party software policy	Evaluate whether to continue using the affected vendor
Resume operations	Following successful validation and cleanup

6. Lessons Learned & Reporting

Step	Action
------	--------

Conduct RCA	Identify how the backdoored software reached the network and bypassed controls
Strengthen software validation process	Include code-signing validation, sandbox testing and digital signatures
Share IOCs	Internally and via threat-sharing platforms (e.g., ISAC, CERTs)
Update procurement and vendor risk policy	Ensure vendors meet minimum security and update transparency standards
Report incident	If sensitive data was impacted or regulatory disclosure is required

Tools Typically Involved

- EDR/XDR (e.g., CrowdStrike, Cortex XDR, Microsoft Defender ATP)
- SIEM (e.g., Splunk, Sentinel, QRadar)
- Threat Intelligence Platforms (e.g., MISP, Anomali, Recorded Future)
- File Integrity Monitoring (e.g., Tripwire, OSSEC)
- Vulnerability Management Tools (e.g., Qualys, Tenable)
- Sandbox Analysis (e.g., Any.Run, Joe Sandbox)

Success Metrics

Metric	Target
Initial Detection to Isolation	<30 minutes from alert
Vendor Verification & IOC Correlation	<1 hour
Eradication of Backdoored Software	<6 hours
Patch Management Policy Update	Within 2 business days
RCA and Executive Report	Within 3 business days

SOC Incident Response Playbook 17: Malware-Laced PDF Uploads to Public Portals

Scenario

An attacker uploads a PDF file containing embedded malware (e.g., macro, JavaScript, shellcode) to a legitimate online portal hosted by the organisation. Internal staff later downloads and opens the file, triggering code execution that could lead to endpoint compromise, command-and-control communication or data theft.

Incident Classification

Category	Details
Incident Type	Malicious File Upload – Drive-by Execution
Severity	High
Priority	High
Detection Sources	EDR/XDR, Web Application Firewall (WAF), Antivirus Alerts, Sandbox Analysis, SIEM

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Implement file upload scanning	Use antivirus or sandbox to scan all uploads at the perimeter
Apply file type restrictions	Allow only specific file types (e.g., PDF, DOCX) and scan file content
Harden web portals	Validate file extensions and block scripts/macros within files
Configure sandbox detonation	Automatically detonate all uploaded PDFs before user access
Educate internal users	On phishing PDFs, macro-based payloads and safe previewing methods

2. Detection & Analysis

Step	Action
Alert triggered	EDR detects PDF-based payload execution or sandbox flags file as malicious
Identify source of PDF	Check upload logs and portal submission metadata (IP, email, time)
Analyse payload behaviour	Determine if it used embedded macros, exploit kits or dropped files

Assess user interaction	Did the file get opened, downloaded or forwarded internally?
MITRE ATT&CK mapping	T1203 (Exploitation for Client Execution), T1059 (Command & Scripting Interpreter), T1566.001 (Phishing: Spearphishing Attachment)

3. Containment

Step	Action
Isolate affected endpoint(s)	Immediately quarantine any host that opened the malicious PDF
Block file hash across systems	Prevent further download/execution of the same file
Disable portal file link	Remove access to the uploaded file for other users
Notify SOC and IT support team	Begin internal awareness and investigation

4. Eradication

Step	Action
Remove malware and dropped artefacts	Delete suspicious registry entries, files and persistence mechanisms
Clean user mailbox and shared folders	If file was emailed or stored elsewhere internally
Investigate lateral movement	Check for credential theft or remote access tools deployed post-execution
Patch vulnerable PDF viewers or document software	That allowed exploit execution

5. Recovery

Step	Action
Restore endpoint from backup or validate cleanup	Ensure clean baseline before reconnecting to network
Re-enable access to portal if safe	After upload filters and scanning tools are confirmed functional
Monitor user and system	For post-incident anomalies over next 1–2 weeks
Conduct internal awareness	Targeted training for affected team or department

6. Lessons Learned & Reporting

Step	Action
Review upload validation process	Was the file scanning or extension check bypassed?
Improve sandbox integration	Ensure full detonation coverage and alert enrichment in SIEM
Create detection signatures	For similar PDF payloads using YARA, regex or EDR rules
Document full incident flow	For compliance, legal and executive reporting
Report to CERT or external regulator	If customer data or sensitive systems were impacted

Tools Typically Involved

- EDR/XDR (e.g., CrowdStrike, Microsoft Defender, SentinelOne)
- Antivirus/Sandbox (e.g., Any.Run, Joe Sandbox, Cuckoo)
- WAF/Reverse Proxy (e.g., Cloudflare, F5, Imperva)
- SIEM (e.g., Sentinel, Splunk)
- File Integrity Monitoring
- Web Portal Logs (Nginx, Apache or app-layer)

Success Metrics

Metric	Target
Detection to Containment Time	<15 minutes
File Removal or Quarantine	<30 minutes from alert
Endpoint Remediation Time	<4 hours
Upload Validation Update	Within 1 business day
End-user Awareness Improvement	≥ 90% pass rate on post-incident phishing test

SOC Incident Response Playbook 18: Account Takeover via Legacy Authentication Protocols

Scenario

An attacker uses brute force, credential stuffing or stolen credentials to gain access to user accounts through legacy authentication protocols such as IMAP, POP3, SMTP AUTH or NTLM. These protocols often do not support MFA, allowing the attacker to bypass modern authentication policies and gain persistent access to mailboxes, VPNs or internal systems.

Incident Classification

Category	Details
Incident Type	Credential Compromise – Legacy Authentication Abuse
Severity	High
Priority	High
Detection Sources	Identity Provider Logs (e.g., Azure AD Sign-In Logs), SIEM, Email Gateway Logs, CASB, EDR

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Disable legacy protocols	Globally block IMAP, POP3, SMTP AUTH unless explicitly required
Monitor authentication types	Audit sign-ins using legacy protocols in SIEM or identity platforms
Enforce MFA for all users	Including service accounts and users with mailbox access
Enable smart lockouts and password protection	Prevent brute force and spray attempts using risk-based policies
Set up alerting	For unusual sign-ins using non-browser clients or from legacy protocols

2. Detection & Analysis

Step	Action
Alert triggered	Sign-in via legacy protocol from suspicious IP or geo-location
Review authentication logs	Identify IP address, user agent, protocol and success/failure rates
Confirm successful login without MFA	Indicating protocol bypass

Cross-reference user activity	Review mailbox access, sent emails, VPN logs and file access logs
MITRE ATT&CK mapping	T1078.004 (Valid Accounts: Cloud Accounts), T1110.003 (Credential Stuffing), T1056.001 (Input Capture: Keylogging)

3. Containment

Step	Action
Block malicious IPs	At firewall, reverse proxy or conditional access policy level
Disable legacy protocol access	For affected users and tenant-wide where possible
Reset credentials	Immediately change the password for compromised accounts
Revoke sessions and tokens	Ensure the attacker is logged out across all platforms

4. Eradication

Step	Action
Review and delete malicious email rules	Such as forwarding rules or hidden inbox rules
Search for signs of exfiltration or abuse	Sent items, unusual downloads, third-party integrations
Scan for persistence	Rogue OAuth apps or backdoors installed via older protocols
Validate user devices	Re-enrol in endpoint protection if compromise extended to the host

5. Recovery

Step	Action
Re-enable account with modern auth only	After ensuring protocol lockout and MFA are enforced
Monitor user activity	For anomalies over the next 7–14 days post-reset
Educate user	On signs of account misuse, reporting procedures and personal device hygiene
Resume operations	After clean authentication posture is confirmed

6. Lessons Learned & Reporting

Step	Action
Review protocol usage across the organisation	Reduce attack surface by eliminating legacy protocol dependencies

Improve detection and alerting	Add SIEM rules for legacy protocol sign-ins and impossible travel
Update security baselines	Document which systems should or should not allow legacy protocols
Report if sensitive data was accessed	Follow relevant disclosure regulations and notify impacted users
Conduct awareness training	Focused on credential hygiene and recognising account misuse

Tools Typically Involved

- Identity Provider Logs (e.g., Azure AD, Okta, Google Workspace)
- SIEM (e.g., Sentinel, Splunk)
- Email Gateway (e.g., Microsoft Defender for Office 365, Proofpoint)
- EDR/XDR (e.g., CrowdStrike, Microsoft Defender)
- CASB (e.g., Microsoft Defender for Cloud Apps, Netskope)
- Firewall and Reverse Proxy Logs

Success Metrics

Metric	Target
Account Lockout/Reset Time	<15 minutes from detection
Legacy Protocol Block Completion	Within 1 business day
Full RCA and User Review	Within 3 business days
Protocol Abuse Detection Coverage	≥ 95% of accounts monitored
User Retraining Completion	100% of affected users briefed within 5 days

SOC Incident Response Playbook 19: Data Tampering in Business-Critical Databases

Scenario

A threat actor, either an insider with privileged access or an external actor using compromised credentials, modifies, deletes or corrupts data in a critical database (e.g., ERP, CRM, HRMS) without authorisation. These changes can be subtle (e.g., invoice manipulation, salary edits) or destructive (e.g., wiping logs, disabling triggers).

Incident Classification

Category	Details
Incident Type	Integrity Violation – Unauthorised Data Modification
Severity	High
Priority	High
Detection Sources	Database Activity Monitoring (DAM), SIEM, Application Logs, User Behaviour Analytics (UBA), Change Control Systems

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enable full query logging	On all production databases, especially those with sensitive records
Deploy DAM tools	e.g., Imperva DAM, IBM Guardium, native MySQL/Azure audit
Implement strict RBAC	Separate read, write and admin roles; monitor privileged users
Enforce change control workflows	Track every legitimate schema or data change through ticketing
Set up anomaly detection	Alert on bulk updates, schema tampering or time-based abuse

2. Detection & Analysis

Step	Action
Alert triggered	Anomalous query or data pattern detected (e.g., UPDATE salary SET..., DROP table or changes outside business hours)
Identify user, host and time	Cross-reference with IAM logs and session metadata
Validate if change is authorised	Check ticketing system or change request ID

Query data modification logs	Determine what rows, tables or columns were impacted
MITRE ATT&CK mapping	T1071.001 (Application Layer Protocol: Web), T1556.002 (Modify Authentication Process), T1565.002 (Stored Data Manipulation)

3. Containment

Step	Action
Revoke or suspend user access	Especially if privilege escalation or abuse is confirmed
Isolate database if needed	If wider corruption or unauthorised changes are ongoing
Notify data owners and DBAs	Coordinate immediate triage and impact review
Snapshot affected tables	For forensic comparison before restoring clean data

4. Eradication

Step	Action
Remove malicious queries/scheduled jobs	Clean up rogue triggers, procedures or scripts
Reset or reassign user credentials	Especially for shared accounts or escalated users
Revert unauthorised changes	Use audit logs or backup to restore integrity
Patch database vulnerabilities	If SQL injection or misconfig allowed access

5. Recovery

Step	Action
Restore full data integrity	Validate record accuracy post-rollback or patch
Resume operations with monitoring	Enable heightened logging for impacted datasets/users
Audit all access paths	Confirm no other vectors were used to affect the database
Document business impact	Report on financial, operational or reputational damage

6. Lessons Learned & Reporting

Step	Action
Perform full RCA	Was this insider misuse, lateral movement or app-layer abuse?
Update alerting thresholds and rules	Improve detection for slow or stealthy tampering patterns

Enhance database security posture	Use column-level encryption, least privilege and deny-all by default
Communicate with stakeholders	Legal, compliance, audit and management if sensitive records were changed
Share IOCs internally	And externally if applicable (e.g., industry ISACs, regulators)

Tools Typically Involved

- Database Activity Monitoring (e.g., Imperva, Guardium, AWS CloudTrail for RDS)
- SIEM (Splunk, Sentinel, QRadar)
- User & Entity Behaviour Analytics (e.g., Exabeam, Securonix)
- Change Control Systems (e.g., Jira, ServiceNow)
- IAM Logs (Azure AD, Okta)
- Forensics and Backup Platforms (e.g., Veeam, Rubrik, native DB recovery)

Success Metrics

Metric	Target
Detection to User Suspension	<15 minutes
Data Recovery Time	<4 hours for critical tables
RCA Completion	<3 business days
Alerting Rule Update	Within 2 business days
Privileged Access Review	Completed within 5 business days

SOC Incident Response Playbook 20: DNS-Based C2 from Embedded IoT Devices

Scenario

An attacker compromises an IoT or embedded device (e.g., IP camera, sensor, printer, HVAC controller) within the corporate environment. The device maintains persistent command-and-control (C2) communication using DNS tunnelling (e.g., via TXT, NULL, A records) to evade perimeter firewalls and transmit data covertly.

Incident Classification

Category	Details
Incident Type	Covert Communication – DNS Tunnelling / IoT C2
Severity	High
Priority	High
Detection Sources	NDR (e.g., Darktrace, Corelight), DNS Logs, SIEM, Firewall Logs, IoT Security Platform

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Segment IoT networks	Use VLANs and firewalls to isolate IoT traffic from corporate networks
Monitor all DNS traffic	Especially to unknown or dynamic domains from non-standard devices
Enforce DNS sinkholing	Block known C2 and suspicious DNS resolvers using RPZ or firewall rules
Deploy NDR and IoT visibility platforms	Monitor anomalous DNS behaviour and asset fingerprinting
Maintain asset inventory	Track all connected embedded and IoT devices with MAC, IP, OS and role

2. Detection & Analysis

Step	Action
Alert triggered	Unusual DNS queries detected from IoT device to external domain (e.g., long subdomains, rare TLDs or excessive frequency)
Analyse DNS query patterns	Check for high entropy, beaconing or tunnelling behaviour
Identify the device and location	Map MAC/IP to physical location and asset inventory

Validate payload indicators	Are the DNS records exfiltrating encoded data (e.g., Base64, hex)?
MITRE ATT&CK mapping	T1071.004 (Application Layer Protocol: DNS), T1020 (Automated Exfiltration), T1086 (PowerShell for payload delivery if Windows IoT)

3. Containment

Step	Action
Block DNS queries to malicious domains	Via DNS firewall, RPZ or upstream DNS sinkhole
Isolate the device from the network	At switch or NAC level to prevent further communication
Alert OT or IoT management teams	Begin device-specific triage and inspection
Disable dynamic DNS updates	If abused for endpoint tracking

4. Eradication

Step	Action
Reflash firmware or factory reset	If malware persistence is confirmed on the device
Remove rogue DNS resolver settings	Ensure only corporate DNS resolvers are used
Clean up device credentials and backdoors	If login portals or services were exposed externally
Patch known firmware vulnerabilities	Or replace device if no update is available

5. Recovery

Step	Action
Reconnect device to isolated VLAN	Only after ensuring clean state and full validation
Monitor DNS traffic from device	For anomalies during post-reconnection period
Conduct functional testing	Ensure operational use cases are not impacted by containment steps
Resume normal operations	Once confirmed secure and compliant with security baseline

6. Lessons Learned & Reporting

Step	Action
Update DNS detection logic	Enrich with entropy scoring, unusual record types, beaconing intervals

Review IoT security policies	Mandate minimum patching, logging and isolation requirements
Update asset visibility tools	Ensure all embedded devices are accounted for and regularly scanned
Share IOCs and detection signatures	Internally and with IoT security vendors if novel malware was involved
Report to CERT if regulatory scope is impacted	Especially if C2 was tied to targeted attacks or critical systems

Tools Typically Involved

- NDR (e.g., Corelight, Darktrace, Vectra)
- DNS Logging/Analytics (e.g., Infoblox, Zeek, Bind)
- SIEM (Splunk, Sentinel, QRadar)
- IoT Security Platforms (e.g., Armis, Forescout)
- Firewall and NAC Systems
- Passive Asset Discovery (e.g., Rumble, Qualys)

Success Metrics

Metric	Target
Detection to Device Isolation Time	<10 minutes
DNS Sinkhole Rule Application	<30 minutes
Firmware Reflash or Replacement	<6 hours
RCA and Asset Update	Within 3 business days
Long-Term DNS C2 Detection Coverage	≥ 95% of IoT endpoints monitored

SOC Incident Response Playbook 21: Initial Access via Malicious Browser Extensions

Scenario

An attacker tricks a user into installing a malicious browser extension (e.g., from a fake Chrome Web Store listing, phishing email or bundled installer). Once installed, the extension gains access to cookies, credentials, session tokens, clipboard content or can redirect the user's traffic, leading to data theft or further compromise.

Incident Classification

Category	Details
Incident Type	Initial Access – Malicious Extension / Browser Hijack
Severity	Medium to High (depends on access scope)
Priority	High
Detection Sources	EDR, Browser Management Tools, CASB, Proxy Logs, UBA, SIEM

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enforce managed browser policies	Use enterprise controls (e.g., Google Admin, Intune, GPO) to block unapproved extensions
Monitor extension installations	With endpoint or browser monitoring agents
Allowlist trusted extensions	Prevent installation of anything not explicitly approved
Educate users	About risks of installing random browser add-ons or productivity tools
Set alerting rules	For uncommon browser extensions or permissions abuse

2. Detection & Analysis

Step	Action
Alert triggered	Suspicious browser behaviour detected (e.g., credential access, network redirection)
Identify affected user and host	From browser telemetry, proxy logs or EDR alerts
Investigate installed extensions	Collect extension IDs, permissions, install sources and version
Analyse extension behaviour	Check for exfiltration, script injection or suspicious API usage

MITRE ATT&CK mapping	T1176 (Browser Extensions), T1056.001 (Input Capture), T1556 (Modify Authentication Process)
----------------------	--

3. Containment

Step	Action
Remove the extension from browser	Via browser management tools or manual cleanup
Disconnect the endpoint from the internet	If session hijacking or credential harvesting is suspected
Revoke exposed session tokens	In identity provider or affected SaaS platforms
Alert IT and application owners	Especially for apps accessed from the compromised session

4. Eradication

Step	Action
Scan for persistence or malware	Ensure the extension didn't drop files or add startup entries
Clean browser profile	Remove cached data, cookies, extension settings and saved passwords
Reinstall browser in clean state	If necessary, especially for unmanaged endpoints
Re-enable enterprise browser policy enforcement	To prevent recurrence

5. Recovery

Step	Action
Reset passwords for all accessed apps	Especially if session tokens or autofilled credentials were exposed
Reconnect to the network	Once device is verified clean and extension removed
Monitor user activity	For continued misuse or shadow extensions reinstalled by user
Educate user involved	Highlight what caused the issue and what to avoid

6. Lessons Learned & Reporting

Step	Action
Update browser security policy	Consider switching to managed profiles or VDI with restricted browser access
Add extension to blocklists or browser threat intel	Share the extension ID hash and threat behaviour indicators

Improve detection rules	Add logic for browser extension permission changes or unusual calls (e.g., chrome.tabs.executeScript)
Document the full compromise chain	For audit and compliance reporting
Report to Google/Mozilla/Microsoft	If the extension is published in a known store

Tools Typically Involved

- EDR/XDR (e.g., Microsoft Defender for Endpoint, CrowdStrike)
- SIEM (e.g., Splunk, Sentinel)
- Browser Management Platforms (e.g., Google Admin Console, Intune, Jamf)
- CASB (e.g., Microsoft Defender for Cloud Apps)
- UBA/UEBA Platforms (e.g., Securonix, Exabeam)
- Threat Intelligence Feeds (for known malicious extension IDs)

Success Metrics

Metric	Target
Extension Removal Time	<30 minutes from detection
Token Revocation Time	<1 hour
Policy Enforcement Coverage	100% of managed browsers within 2 business days
User Awareness Follow-up	Completed within 3 business days
IOC Sharing with Browser Vendors	Within 1 day if publicly listed

SOC Incident Response Playbook 22: Unauthorised Use of Offensive Security Tools in Internal Networks

Scenario

An attacker, insider or red teamer runs offensive security tools (e.g., Mimikatz, Cobalt Strike, BloodHound, Empire) within the internal environment to extract credentials, perform recon, move laterally or establish command and control. This can be a sign of a red team exercise, insider threat or active compromise by an adversary.

Incident Classification

Category	Details
Incident Type	Tool-Based Malicious Activity – Credential Theft / Lateral Movement
Severity	Critical
Priority	Immediate
Detection Sources	EDR/XDR, SIEM, Process Monitoring, Threat Intel, Sysmon, Network Traffic Analytics

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Deploy EDR and behaviour-based detection	Capable of flagging Mimikatz, Cobalt Strike beacons, etc.
Enable Sysmon or advanced logging	Track command-line arguments, DLL loads, LSASS access
Maintain threat hunting playbooks	Based on tool-specific TTPs and YARA/Sigma rules
Create allowlist of known red team tools	To differentiate sanctioned exercises from real threats
Integrate threat intel feeds	For hashes, signatures and beacon infrastructure

2. Detection & Analysis

Step	Action
Alert triggered	Detection of known tool patterns (e.g., sekurlsa::logonpasswords, beacon.exe, powershell Empire.ps1)
Identify host and user	Determine who executed the tool and on which endpoint
Confirm red team vs threat actor	Check if activity aligns with a scheduled test or unplanned use

Analyse scope of access	Determine if credentials were dumped, movement occurred or persistence established
MITRE ATT&CK mapping	T1003 (OS Credential Dumping), T1059 (Command Execution), T1021 (Remote Services), T1105 (Ingress Tool Transfer)

3. Containment

Step	Action
Isolate the host from the network	Immediately prevent lateral movement or beaconing
Suspend involved user accounts	If an insider threat or compromised account is suspected
Block tool binaries and hashes	In EDR, AV and NGFW platforms
Redirect C2 domains/IPs	To sinkholes or blocklists

4. Eradication

Step	Action
Remove malicious binaries, scripts and persistence mechanisms	E.g., scheduled tasks, WMI subscriptions, registry entries
Re-image if system trust is broken	Especially for domain controllers or admin workstations
Rotate exposed credentials	Prioritise privileged and service accounts affected
Scan for lateral movement artefacts	Use BloodHound data, user login logs and PowerShell transcripts

5. Recovery

Step	Action
Restore systems from clean backups	If compromise is extensive or tool modified core binaries
Reinstate users with strict monitoring	Temporarily apply least privilege and behavioural watch
Harden detection rules	Improve detections using endpoint telemetry and network signatures
Resume operations	Once verified clean and logs reviewed for hidden persistence

6. Lessons Learned & Reporting

Step	Action
------	--------

Conduct full RCA	How was the tool introduced? USB, phishing, RDP session?
Tune and test new rules	Against variants or obfuscated tools
Run purple team exercises	To validate controls and analyst readiness
Update red team coordination SOP	Ensure future test activities are pre-registered and whitelisted
Report if required	Especially if internal access or PII was exfiltrated

Tools Typically Involved

- EDR/XDR (e.g., CrowdStrike, SentinelOne, Cortex XDR)
- SIEM (e.g., Splunk, Sentinel, QRadar)
- Sysmon + Windows Event Logs
- YARA/Sigma Detection Rules
- Threat Hunting Platforms (e.g., Velociraptor, LimaCharlie)
- Threat Intel Platforms (e.g., MISP, Recorded Future)

Success Metrics

Metric	Target
Detection to Containment Time	<10 minutes
Credential Rotation Time	<2 hours
Full Threat Scope Determination	<4 hours
Rule Tuning and IOC Sharing	Within 2 business days
Red Team Coordination Compliance	100% of test tools registered and approved

SOC Incident Response Playbook 23: Lateral Movement via Shared Cloud Drives

Scenario

An attacker with access to a compromised user account leverages corporate cloud storage services (e.g., Google Drive, OneDrive, Dropbox) to move laterally by sharing malicious files (e.g., macro-laced documents, weaponised PDFs or shortcut links) with other employees. Recipients who open these files inadvertently expand the attacker's reach.

Incident Classification

Category	Details
Incident Type	Lateral Movement – Cloud Drive Exploitation
Severity	High
Priority	High
Detection Sources	CASB, SIEM, Identity Logs, Cloud Audit Logs, EDR, Email Security Gateway

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enforce file sharing policies	Block sharing with external domains unless whitelisted
Use CASB for visibility	Detect unusual file sharing, download/upload spikes and excessive permissions
Apply DLP rules	Prevent uploading of sensitive or executables via cloud drive
Implement sandbox file analysis	For shared files before user access
Train users	To validate links/files received even from internal sources

2. Detection & Analysis

Step	Action
Alert triggered	Unusual sharing behaviour or malware detected in shared file
Identify source account	Determine who created/shared the file and from which endpoint/IP
Analyse file content	Use sandbox or static analysis to determine file behaviour
Review access logs	Who viewed/downloaded or interacted with the file? From where? When?

MITRE ATT&CK mapping	T1560.001 (Archive via Utility), T1203 (Exploit Client), T1105 (Ingress Tool Transfer)
----------------------	--

3. Containment

Step	Action
Revoke shared file links	In the cloud storage admin portal or via API
Suspend involved user account(s)	If sharing was unauthorised or malicious
Quarantine endpoint	Of user who uploaded or executed the malicious file
Alert affected users	Instruct not to open the file and reset their credentials if access is suspected

4. Eradication

Step	Action
Delete malicious files	From all shared drives, including personal and shared folders
Remove malicious browser extensions or sync clients	Used to automate sharing or file sync abuse
Block file hashes and signatures	Across endpoint security tools and email platforms
Reset compromised accounts	Ensure attackers cannot reuse cloud tokens or sessions

5. Recovery

Step	Action
Restore from clean versions	If important shared files were deleted or replaced
Reconnect users	After file access is validated and devices are clean
Monitor cloud drive activity	For suspicious post-incident behaviours
Resume collaboration tools	After full incident review and controls are enforced

6. Lessons Learned & Reporting

Step	Action
Update CASB/EDR/Email alerting rules	For internal sharing anomalies and file abuse
Review cloud app governance	Only allow approved cloud storage platforms and disable legacy sync clients
Conduct awareness training	Focused on internal threat propagation and safe collaboration practices

Document incident for audit	Include shared link metadata, access logs and file analysis results
Notify legal or compliance	If regulated data was shared or accessed during the incident

Tools Typically Involved

- CASB (e.g., Microsoft Defender for Cloud Apps, Netskope, Lookout)
- Cloud Storage Admin Consoles (e.g., Google Workspace Admin, Microsoft 365 Admin)
- SIEM (e.g., Sentinel, Splunk)
- Sandbox Analysis (e.g., Any.Run, Joe Sandbox)
- DLP (e.g., Microsoft Purview, Forcepoint, Symantec DLP)
- Email Security Gateway (e.g., Proofpoint, Mimecast)

Success Metrics

Metric	Target
Shared File Link Revocation	<15 minutes from detection
Infected User Account Suspension	<30 minutes
File Eradication from All Folders	<2 hours
User Notification and Credential Reset	Within 4 hours
CASB and Policy Tuning	Within 1 business day

SOC Incident Response Playbook 24: Compromise via Misconfigured SaaS Integrations

Scenario

An attacker exploits a misconfigured SaaS integration (e.g., an unvetted OAuth app connected to Google Workspace, Microsoft 365, Salesforce or Slack) to access user accounts, read mail, extract files or interact with APIs on behalf of the user, bypassing MFA and existing detection mechanisms.

Incident Classification

Category	Details
Incident Type	SaaS Abuse – OAuth/Third-Party App Exploitation
Severity	High
Priority	High
Detection Sources	CASB, Identity Logs, Cloud App Logs, SIEM, SaaS Security Posture Management (SSPM), OAuth App Audit Logs

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enable SaaS app governance	Block unverified or high-risk OAuth apps by default
Use CASB or SSPM tools	To monitor and alert on new third-party app integrations
Review and restrict OAuth scopes	Allow minimal access (e.g., read-only) and monitor write/delete scopes
Conduct app risk assessments	For each newly onboarded SaaS integration
Train users and admins	To avoid authorising unnecessary or risky integrations

2. Detection & Analysis

Step	Action
Alert triggered	Unknown app granted access to sensitive services (e.g., Gmail, SharePoint, Slack DMs)
Identify affected user(s) and app	Collect app name, OAuth scopes, install time, IP address, user agent
Validate whether app is authorised	Check SaaS admin panel or SSPM policy for unapproved apps

Analyse app behaviour	Look for download/export actions, mailbox access, drive listing or message posting
MITRE ATT&CK mapping	T1550.001 (Application Access Token), T1098.001 (Account Manipulation via OAuth), T1110.003 (Credential Access via OAuth Abuse)

3. Containment

Step	Action
Revoke app access	From affected user accounts or tenant-wide using the SaaS admin console
Disable affected user accounts temporarily	If persistent access was abused or impersonation is ongoing
Block app via CASB or SSPM policies	Prevent re-connection and future authorisation
Alert user and IT/security team	Warn of possible data exposure or shadow IT risks

4. Eradication

Step	Action
Remove app tokens and refresh tokens	Fully disconnect the app from account and revoke refresh privileges
Check for downstream abuse	Look for shared links, downloaded files or changed mail rules
Audit other user accounts	To detect whether the app was widely installed across users or groups
Reset affected user credentials and session tokens	If lateral movement or data manipulation occurred

5. Recovery

Step	Action
Resume user access after cleanup	Ensure app is removed and no unauthorised behaviour persists
Restore tampered data	If the app deleted, altered or shared sensitive information
Harden SaaS app policies	Disable risky OAuth grant types and restrict high-scope apps to admins only
Monitor app reappearance attempts	Through CASB/SSPM integrations

6. Lessons Learned & Reporting

Step	Action
Conduct full RCA	How was the app authorised? Who installed it? Was it approved?
Strengthen SaaS onboarding process	Add approval flows, risk scoring and app reviews
Enforce app allowlisting	Allow only specific pre-approved SaaS connectors
Share app IOCs internally	Include domain names, app IDs, scopes and behavioural patterns
Report externally if required	Especially for breaches of PII, financial data or regulated services

Tools Typically Involved

- CASB (e.g., Microsoft Defender for Cloud Apps, Netskope, McAfee MVISION)
- SaaS Admin Consoles (e.g., Google Workspace, Microsoft 365, Slack, Salesforce)
- SIEM (e.g., Splunk, Sentinel, Exabeam)
- SSPM (e.g., Obsidian, AppOmni, Adaptive Shield)
- OAuth Logs and App Audit Logs
- Identity Providers (e.g., Okta, Azure AD)

Success Metrics

Metric	Target
OAuth App Revocation Time	<30 minutes from detection
User Notification and Containment	<1 hour
Policy Tuning to Block App	Within 4 hours
RCA and Report Finalisation	Within 3 business days
SaaS Integration Governance Review	Completed quarterly

SOC Incident Response Playbook 25: Privilege Escalation via Vulnerable Drivers

Scenario

A threat actor executes a known vulnerable driver (e.g., RTCore64.sys, Capcom.sys, AsrDrv101.sys) to exploit kernel-mode flaws, bypass endpoint protection or gain SYSTEM-level access on a compromised host. These drivers may be signed and appear legitimate, making detection difficult without behavioural monitoring.

Incident Classification

Category	Details
Incident Type	Privilege Escalation – Kernel Exploit via Vulnerable Driver
Severity	Critical
Priority	Immediate
Detection Sources	EDR, Sysmon, Kernel Event Logs, SIEM, Vulnerability Management Tools, Exploit Protection Logs

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enable driver blocklists	Use Microsoft's kernel driver block policy via Defender for Endpoint
Monitor signed driver loading events	Use Sysmon Event ID 6 and EDR telemetry
Maintain list of banned hashes and filenames	Based on threat intel and recent CVEs
Configure exploit protection	Enable kernel-mode protection features and memory integrity
Integrate vulnerability feeds	Track emerging driver vulnerabilities (e.g., CISA KEV, NVD)

2. Detection & Analysis

Step	Action
Alert triggered	Detection of known vulnerable driver loaded, abnormal kernel access or SYSTEM-level exploit
Identify driver name and hash	Check if the binary is signed, who installed it and when
Correlate with suspicious behaviour	e.g., disabling AV, creating SYSTEM-level accounts or writing to kernel memory

Check endpoint and user context	Determine if this was part of an admin task or suspicious payload
MITRE ATT&CK mapping	T1068 (Exploitation for Privilege Escalation), T1543.003 (Create or Modify System Process), T1547.006 (Kernel Modules and Extensions)

3. Containment

Step	Action
Isolate the affected host	To prevent driver use in broader lateral escalation
Kill associated processes	Especially dropper processes or tools leveraging the driver
Quarantine driver binary	Use EDR or AV platform to contain the driver executable
Suspend user or admin accounts	If credential misuse or tool installation is confirmed

4. Eradication

Step	Action
Remove vulnerable driver and dependencies	From System32\drivers\, registry service entries and startup configs
Revoke trust for driver certificate (if custom)	Blocklist at EDR or Defender level
Patch the host	Apply kernel updates and security patches for related components
Check for persistence mechanisms	e.g., scheduled tasks, bootkits or registry modifications

5. Recovery

Step	Action
Restore from known good baseline	If system integrity is compromised (e.g., kernel tampering)
Re-enable security controls	That may have been disabled during the attack
Validate with rootkit scanner	Ensure no deep-level manipulation remains (e.g., GMER, CHKROOTKIT)
Monitor post-cleanup behaviour	For reinstallation attempts or new exploit methods

6. Lessons Learned & Reporting

Step	Action
------	--------

Update detection logic	Add rules for rare driver names, unsigned driver drops and rapid privilege changes
Enforce allowlist for kernel drivers	Through Device Control or application whitelisting tools
Conduct blue team exercise	Simulate similar escalation to test SOC visibility
Report vulnerable drivers	To vendors or authorities if zero-day was used
Share IOCs and TTPs internally	To improve future triage and correlation

Tools Typically Involved

- EDR/XDR (e.g., Microsoft Defender for Endpoint, SentinelOne, CrowdStrike)
- Sysmon (Event ID 6 – Driver Loaded)
- SIEM (Splunk, Sentinel, QRadar)
- Exploit Protection / Core Isolation (Windows Security)
- Driver Blocklists (Microsoft, CISA Known Exploited Vulnerabilities)
- Vulnerability Management Tools (e.g., Tenable, Qualys)

Success Metrics

Metric	Target
Driver Detection to Host Isolation Time	<10 minutes
Binary Quarantine Time	<30 minutes
RCA and Driver Cleanup	Within 1 business day
Block Policy Application	Across all endpoints within 2 days
Awareness Briefing to SOC Analysts	Within 3 business days

SOC Incident Response Playbook 26: Data Exposure via Misconfigured Cloud Storage

Scenario

An internal user or application misconfigures a cloud storage bucket (e.g., Amazon S3, Azure Blob Storage, Google Cloud Storage), unintentionally exposing confidential files such as PII, source code or backups to the internet or to unauthorised internal users. Attackers or researchers may discover and access these files.

Incident Classification

Category	Details
Incident Type	Data Exposure – Misconfigured Storage
Severity	High (especially if regulated data is involved)
Priority	High
Detection Sources	Cloud Security Posture Management (CSPM), SIEM, CASB, Threat Intel Feeds, External Reports

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enforce storage encryption and access policies	e.g., default deny, MFA for write access
Use CSPM to continuously scan cloud configurations	Identify public or over-permissive buckets
Label sensitive data	Apply classification and tagging for automated DLP
Set up alerting for policy violations	Trigger alerts when ACLs, policies or encryption are disabled
Train teams on secure cloud configuration	Include DevOps, developers and project owners

2. Detection & Analysis

Step	Action
Alert triggered	CSPM or CASB flags publicly accessible bucket or weak ACL
Identify exposed bucket and file types	Confirm data sensitivity: PII, source code, credentials, etc.
Validate access logs	Determine who accessed the data and when (if logging enabled)

Check source of report	Internal scan, external researcher or threat actor access?
MITRE ATT&CK mapping	T1530 (Data from Cloud Storage Object), T1565.001 (Stored Data Manipulation)

3. Containment

Step	Action
Revoke public access immediately	Update ACLs or bucket policies to private
Quarantine sensitive files	Move to a secure location with limited access
Notify data owners and legal team	Especially if customer data or regulated files were exposed
Block further uploads to exposed bucket	Until full review is complete

4. Eradication

Step	Action
Review all storage buckets	Across the cloud environment for similar misconfigurations
Apply encryption and versioning	To reduce future exposure risk
Remove backup or temporary files	That don't require ongoing access or exposure
Revoke outdated API keys or IAM tokens	If access credentials were exposed in the bucket

5. Recovery

Step	Action
Validate all access controls	Confirm no other cloud storage misconfigurations exist
Restore files with proper permissions	If access was temporarily disabled
Re-enable access to necessary roles only	Based on least privilege
Resume business operations	Once secured and verified with audit

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	Determine who created the misconfiguration and why it bypassed controls
Improve IaC pipelines	Include bucket security validation before deployment (e.g., Terraform with Sentinel)
Share findings internally	Especially with DevOps and engineering teams

Report externally if required	To regulators, impacted users or responsible disclosure platforms
Review and update cloud security baseline	Apply stricter guardrails for storage creation

Tools Typically Involved

- Cloud Security Posture Management (e.g., Wiz, Prisma Cloud, AWS Config, Microsoft Defender for Cloud)
- SIEM (e.g., Splunk, Sentinel)
- CASB (e.g., Microsoft Defender for Cloud Apps)
- DLP (e.g., Microsoft Purview, Symantec)
- Cloud Native Audit Logs (e.g., AWS CloudTrail, GCP Audit Logs)
- Identity and Access Management Platforms (e.g., Azure AD, AWS IAM)

Success Metrics

Metric	Target
Public Access Revocation Time	<30 minutes
Notification to Stakeholders	<1 hour
Similar Bucket Review Completion	Within 1 business day
Policy Fix Deployment	Within 2 business days
Post-Incident Security Review	Within 3 business days

SOC Incident Response Playbook 27: Insider Abuse of Monitoring or Admin Tools

Scenario

An insider with administrative access misuses legitimate tools such as Splunk, SolarWinds, Active Directory tools, SCCM or security platforms to view sensitive user data, elevate privileges, create rogue accounts or disable logs, violating internal policies and potentially preparing for data theft or sabotage.

Incident Classification

Category	Details
Incident Type	Insider Threat – Abuse of Admin Tools
Severity	High
Priority	High
Detection Sources	SIEM, EDR, Privileged Access Management (PAM) Logs, UEBA, Audit Logs, Endpoint Logs

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Implement least privilege	Limit admin tool access to only what is required for each role
Enable full audit logging	Track all privileged tool access, changes and sensitive data views
Deploy UEBA or insider threat detection	Monitor for behavioural anomalies by privileged users
Enforce PAM solutions	Record and restrict admin tool sessions
Train admins	On acceptable use policies and consequences of abuse

2. Detection & Analysis

Step	Action
Alert triggered	Unusual access patterns (e.g., off-hours logins, accessing HR records, repeated privilege escalations)
Identify user and tool used	Correlate PAM logs, AD logs and SIEM alerts
Validate access context	Was this activity part of an approved change, ticket or maintenance task?

Review session recordings (if available)	Via PAM or remote access tools
MITRE ATT&CK mapping	T1087 (Account Discovery), T1078 (Valid Accounts), T1556 (Modify Authentication Process), T1003 (Credential Dumping)

3. Containment

Step	Action
Suspend user account	Immediately block further access to admin tools
Isolate affected systems	If changes were made that affect system integrity or visibility
Lock down affected tools	Temporarily restrict use of the abused tool while investigating further
Notify HR and legal teams	Insider threat cases may require coordinated internal response

4. Eradication

Step	Action
Remove unauthorised changes	Revert any account creations, log tampering or policy modifications
Reset shared or reused credentials	Especially if access tokens or service accounts were abused
Audit tool configurations	Ensure no lingering backdoors, rogue jobs or persistent scripts exist
Conduct forensic review of affected systems	Validate no hidden manipulation or malware was introduced

5. Recovery

Step	Action
Restore normal operations	Only after full risk is mitigated and admin accounts are reviewed
Reinstate tool access for other users	With improved oversight and auditing in place
Increase logging levels temporarily	To monitor for any follow-up attempts or unnoticed abuse
Confirm sensitive data integrity	Especially if financial or HR data was accessed

6. Lessons Learned & Reporting

Step	Action
------	--------

Conduct RCA and internal review	What controls failed? Was there insufficient oversight or segmentation?
Update admin access policies	Include stricter monitoring and cross-functional approvals for sensitive actions
Improve alerts for admin misuse	Add rules for data exfiltration patterns, excessive queries and abnormal script use
Conduct insider threat awareness training	Re-educate IT and SOC teams about acceptable usage boundaries
Report to regulators or customers (if needed)	Especially in regulated environments (e.g., healthcare, finance)

Tools Typically Involved

- SIEM (e.g., Splunk, Sentinel, QRadar)
- Privileged Access Management (e.g., CyberArk, BeyondTrust, Thycotic)
- UEBA / Insider Threat Platforms (e.g., Securonix, Varonis, ObserveIT)
- EDR/XDR (e.g., Cortex XDR, CrowdStrike)
- Audit Tools (e.g., Microsoft ATA, AWS CloudTrail, Windows Event Logs)
- Change Tracking Platforms (e.g., Tripwire, ManageEngine)

Success Metrics

Metric	Target
Account Suspension Time	<10 minutes from detection
Forensic Review of Tool Usage	Within 4 hours
Full RCA and Policy Update	Within 3 business days
Alert Rule Refinement	Within 2 business days
PAM Session Coverage	≥ 95% of all privileged sessions monitored

SOC Incident Response Playbook 28: Backdoor Persistence via Rogue Browser Update Mechanisms

Scenario

An attacker lures a user to a compromised website or phishing page that prompts them to install a "browser update." Instead of a legitimate update, the user installs malware that creates a persistent backdoor, allowing remote access, data exfiltration or further lateral movement.

Incident Classification

Category	Details
Incident Type	Malware Delivery – Social Engineering / Persistence
Severity	High
Priority	High
Detection Sources	EDR, DNS Logs, Proxy Logs, Firewall, SIEM, Sandbox Analysis Tools

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enable endpoint protection with behaviour detection	Capable of detecting post-install execution anomalies
Block known rogue update domains	Use DNS filtering, firewall and threat intel integration
Monitor browser download behaviour	Flag abnormal executable downloads initiated via browser
Educate users	About common social engineering tactics involving fake updates
Deploy sandboxing	For unknown downloads before execution

2. Detection & Analysis

Step	Action
Alert triggered	Suspicious file download detected following web activity
Identify file hash and execution path	Confirm file was dropped in a non-standard location (e.g., %AppData%)
Analyse execution behaviour	Look for persistence mechanisms (registry run keys, scheduled tasks)
Map file source	Determine domain or IP used to host the fake update

MITRE ATT&CK mapping	T1189 (Drive-by Compromise), T1059 (Command Execution), T1547 (Persistence via Registry/Scheduled Task), T1105 (Ingress Tool Transfer)
----------------------	--

3. Containment

Step	Action
Isolate the affected host	Prevent further C2 communication or lateral movement
Kill malicious processes	Use EDR to terminate backdoor operations
Quarantine the fake update executable	Block by hash and signature in endpoint and perimeter tools
Notify user and affected business unit	Begin secure communication to gather incident context

4. Eradication

Step	Action
Remove persistence mechanisms	Delete registry keys, scheduled tasks or startup folder entries
Clean the malware	Use AV/EDR tools or manually delete known dropped files and services
Scan for related indicators	Check for downloader scripts, payload droppers or C2 callbacks
Patch browser and OS	Ensure the environment is not vulnerable to exploit kits or older exploits

5. Recovery

Step	Action
Reconnect system after validation	Once threat is fully removed and endpoint is hardened
Monitor for reinfection attempts	Watch for beaconing, re-downloads or related phishing attempts
Re-train user on safe browsing habits	Address the source of the incident with contextual training
Resume operations	After confirmation of integrity and no residual effects

6. Lessons Learned & Reporting

Step	Action
Review browser and endpoint protection policies	Enforce auto-update via admin channels only

Update alerting thresholds	For browser downloads of .exe, .js or other script-based files
Conduct phishing simulations	Involving fake update prompts to measure user resilience
Share threat indicators	Including file hashes, URLs, domains and C2 infrastructure
Document full RCA	For audit trail and potential law enforcement reporting

Tools Typically Involved

- EDR/XDR (e.g., CrowdStrike, SentinelOne, Microsoft Defender)
- SIEM (e.g., Splunk, Sentinel)
- DNS & Proxy Logs (e.g., Cisco Umbrella, Zscaler)
- Threat Intelligence Feeds (e.g., AbuseIPDB, AlienVault OTX)
- URL Sandboxing (e.g., Any.Run, VirusTotal)
- Email Gateway / Web Filter (e.g., Mimecast, Proofpoint, Palo Alto URL Filtering)

Success Metrics

Metric	Target
Host Isolation Time	<10 minutes
Malicious File Quarantine	<30 minutes
User Notified and Re-educated	Within 1 business day
IOC Sharing and Policy Update	Within 2 business days
Browser Policy Enforcement Check	100% coverage within 5 business days

SOC Incident Response Playbook 29: Token Theft via Cross-Site Scripting (XSS)

Scenario

An attacker discovers a stored or reflected XSS vulnerability in a corporate web application. By injecting malicious JavaScript, they steal session cookies, JWTs or OAuth tokens from logged-in users. This enables the attacker to impersonate victims without needing credentials or bypassing MFA.

Incident Classification

Category	Details
Incident Type	Web Exploitation – Token Hijacking via XSS
Severity	High
Priority	High
Detection Sources	WAF, SIEM, Web Server Logs, Browser Telemetry, EDR, Bug Bounty Reports

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Implement Content Security Policy (CSP)	To block inline scripts and limit JS sources
Set HttpOnly and Secure flags	On cookies to prevent client-side access and enforce HTTPS
Conduct regular code reviews and dynamic testing	For web app vulnerabilities (e.g., using OWASP ZAP, Burp Suite)
Monitor WAF for XSS patterns	Flag common payloads like <script>, document.cookie, fetch()
Use bug bounty programs or pentesting	To detect XSS vulnerabilities early

2. Detection & Analysis

Step	Action
Alert triggered	WAF or SIEM logs XSS payload or suspicious JS execution
Identify exploited endpoint	Locate the exact parameter or page vulnerable to injection
Correlate user sessions	Determine who visited the page and had tokens stolen

Inspect malicious JS	Was it stealing tokens, sending them to external servers or modifying DOM?
MITRE ATT&CK mapping	T1059.007 (JavaScript Execution), T1557 (Man-in-the-Middle for token theft), T1185 (Browser Session Hijacking)

3. Containment

Step	Action
Take down the vulnerable endpoint or page	Prevent further exposure
Revoke exposed tokens or sessions	Via identity provider or application back-end
Block outbound traffic to attacker-controlled domains	Used to receive stolen data
Notify affected users	Prompt for forced logout and credential reset as needed

4. Eradication

Step	Action
Patch the XSS vulnerability	Escape user input, validate parameters, use proper output encoding
Clean up application code	Review all injection points for similar flaws
Rotate signing keys for tokens	If JWT secrets or refresh tokens may have been compromised
Conduct secure code deployment	With review and testing for all hotfixes

5. Recovery

Step	Action
Resume application services	After patch is tested and verified in staging/production
Monitor user re-authentication	Ensure only legitimate logins are observed post-patch
Conduct post-incident scans	Look for new signs of token misuse or reinjection of payloads
Resume WAF and DLP alerting	With tuned rules for updated protections

6. Lessons Learned & Reporting

Step	Action
------	--------

Conduct full RCA	How was the XSS introduced and how long was it exploitable?
Educate developers	On secure coding practices, escaping and content handling
Update WAF rules and SIEM use cases	To detect token theft patterns and JS exfiltration attempts
Share findings internally	Across dev, security and ops teams for awareness
Report externally if PII or regulated data was involved	Fulfil legal, regulatory or contractual obligations

Tools Typically Involved

- WAF (e.g., Cloudflare, AWS WAF, Azure WAF)
- SIEM (e.g., Sentinel, Splunk)
- Identity Providers (e.g., Azure AD, Okta, Ping Identity)
- EDR (e.g., CrowdStrike, Defender for Endpoint)
- Web App Scanners (e.g., OWASP ZAP, Burp Suite, Acunetix)
- DLP and Proxy Logs (e.g., Zscaler, Netskope)

Success Metrics

Metric	Target
Time to Patch Vulnerability	<24 hours for critical severity
Token Revocation Completion	<1 hour after confirmation of theft
Affected User Notification	Within 1 business day
Developer Training Completion	Within 5 business days
WAF and SIEM Rule Update	Within 2 business days

SOC Incident Response Playbook 30: Remote Desktop Exposure via Misconfigured Firewall/NAT Rules

Scenario

A system (e.g., Windows server or workstation) is unintentionally exposed to the internet with RDP, VNC or SSH ports open due to misconfigured firewall rules or incorrect NAT settings. Attackers scan for such ports and launch brute-force or exploitation attempts to gain access and move laterally within the network.

Incident Classification

Category	Details
Incident Type	Network Misconfiguration – Remote Access Exposure
Severity	High
Priority	High
Detection Sources	SIEM, Perimeter Firewall Logs, NDR, Cloud Security Scanners, Threat Intel Feeds

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Maintain an updated asset inventory	Map external IPs and exposed services regularly
Implement geo-IP blocking and brute-force protection	At firewall and endpoint level
Restrict RDP/SSH via VPN or jump server	Never expose directly to the internet
Use honeypots or deception tech	To detect scans and exploit attempts early
Enable strong password policies and MFA	Especially for all remote access services

2. Detection & Analysis

Step	Action
Alert triggered	Inbound connections to RDP/SSH from suspicious IPs or excessive login attempts
Identify exposed asset	Cross-reference logs with asset inventory and firewall policies
Review session logs	Look for successful authentications, lateral movement or malware deployment

Perform port scans and config reviews	Confirm exposure state and misconfiguration source
MITRE ATT&CK mapping	T1021.001 (Remote Services: RDP), T1110 (Brute Force), T1133 (External Remote Services)

3. Containment

Step	Action
Immediately block inbound remote access	Via firewall rules or cloud security groups
Isolate the affected host	If access was successful or malware is detected
Rotate credentials	For any accounts that were used during the session
Notify IT/network teams	For coordinated firewall and routing policy updates

4. Eradication

Step	Action
Patch the exposed system	Especially for known RDP/SSH exploits (e.g., BlueKeep, Zerologon)
Reconfigure NAT/firewall	Ensure only approved remote access paths are allowed
Scan for persistence mechanisms	Registry keys, startup entries or remote shells
Conduct forensic review	If compromise is confirmed, validate logs, check for lateral movement, etc.

5. Recovery

Step	Action
Reinstate remote access securely	Only via VPN or jump host, with strict rules and MFA
Restore services if any were taken offline	Validate integrity and review configurations
Monitor for post-incident activity	Watch for beaconing, repeat scans or malware callbacks
Resume operations	After full patching and hardening are complete

6. Lessons Learned & Reporting

Step	Action
------	--------

Conduct RCA	How did the exposure occur? Who applied the firewall rule or NAT config?
Improve firewall change management	Enforce approvals and routine audits for port exposures
Implement external attack surface monitoring	Continuous scanning for open ports or risky services
Document findings	Include timeline, IOCs and affected assets
Report externally if data was accessed	Notify authorities, clients or regulators as required

Tools Typically Involved

- SIEM (e.g., Splunk, Sentinel)
- Firewall Logs and Management Consoles (e.g., Fortinet, Palo Alto, AWS Security Groups)
- NDR Solutions (e.g., Darktrace, ExtraHop)
- Cloud Attack Surface Scanners (e.g., Shodan, Censys, Palo Alto Xpanse)
- EDR (e.g., Microsoft Defender, SentinelOne)
- Vulnerability Scanners (e.g., Tenable, Qualys)

Success Metrics

Metric	Target
Exposure to Block Time	<15 minutes
RDP/SSH Credential Rotation Time	<1 hour
Confirmation of No Lateral Movement	Within 4 hours
Firewall/NAT Rule Review Completion	Within 1 business day
Security Posture Revalidation	Within 3 business days

SOC Incident Response Playbook 31: Business Email Compromise via OAuth Token Abuse

Scenario

An attacker gains access to a user's email account not by stealing credentials, but by tricking the user into authorising a malicious third-party OAuth app. The app is granted broad permissions (e.g., read mail, send mail), allowing the attacker to operate stealthily, bypassing MFA and persisting via refresh tokens.

Incident Classification

Category	Details
Incident Type	Account Compromise – OAuth Token Abuse
Severity	High
Priority	High
Detection Sources	Identity Logs, SIEM, CASB, SSPM, Microsoft 365 / Google Workspace Audit Logs

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Use SSPM or CASB to monitor third-party app usage	Detect new OAuth app grants and risky permissions
Enforce app consent policies	Block user consent for unverified apps or require admin approval
Enable cloud audit logging	For OAuth grants, mail actions and token refresh events
Configure alerts on risky scopes	Such as Mail.ReadWrite, Send.Mail, Drive.Read.All
Educate users on app authorisation risks	Especially phishing tactics with "consent grant" prompts

2. Detection & Analysis

Step	Action
Alert triggered	Unfamiliar app granted high-scope access to a user's email
Identify app ID and scopes	Determine what the app can do (read, send, access files)
Review activity logs	Look for unusual mail sends, mail forwarding or inbox rules

Map user access timeline	Was login followed by suspicious OAuth activity or data access?
MITRE ATT&CK mapping	T1550.001 (Application Access Token), T1071.003 (Email for C2), T1110.003 (OAuth Abuse)

3. Containment

Step	Action
Revoke app access immediately	Via Microsoft 365 / Google Admin console or via Graph API
Invalidate access and refresh tokens	To block any token reuse from the attacker
Notify the user and affected recipients	Especially if malicious mails were sent from the account
Suspend account temporarily if misuse is confirmed	And enforce re-authentication after cleanup

4. Eradication

Step	Action
Conduct full mailbox and file review	Check for data exfiltration or mail rule creation
Remove rogue inbox rules or mail forwards	That may redirect sensitive data externally
Check for impersonation attempts	Such as replies to internal threads with fake invoices or links
Rotate credentials and enable re-authentication	Remove lingering sessions across all devices

5. Recovery

Step	Action
Restore user access securely	With conditional access and MFA enforcement
Monitor post-incident activity	For repeat app grant attempts or login anomalies
Strengthen OAuth governance	Update app blocklists and review app consent settings
Resume business email operations	After validating account integrity and alert quieting

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	How was the app authorised and why wasn't it blocked?
Improve app visibility tools	Implement dashboards to monitor OAuth apps across the organisation

Share IOCs internally	App ID, redirect URIs and attacker infrastructure used for token callback
Update training materials	Focus on consent phishing awareness
Report externally if data was accessed	Fulfil obligations under PDPA/GDPR/industry-specific compliance

Tools Typically Involved

- Microsoft 365 Security Center / Google Admin Console
- CASB (e.g., Microsoft Defender for Cloud Apps, Netskope)
- SIEM (e.g., Sentinel, Splunk)
- SSPM (e.g., AppOmni, Obsidian)
- Identity Providers (e.g., Azure AD, Okta)
- OAuth Log Analytics / Threat Intelligence Platforms

Success Metrics

Metric	Target
OAuth App Revocation Time	<30 minutes from detection
Full Session Revocation	<1 hour
User and Stakeholder Notification	Within 1 business day
RCA and Control Hardening	Within 3 business days
App Blocklist/Policy Update	Completed across all tenants within 2 days

SOC Incident Response Playbook 32: Data Exfiltration via DNS Tunnelling

Scenario

An attacker who has gained access to an internal host uses DNS tunnelling tools (e.g., iodine, dnscat2, Heyoka) to encode data in DNS queries and exfiltrate it to attacker-controlled domains. These DNS requests often look like long, random subdomains of a suspicious domain and bypass perimeter firewalls.

Incident Classification

Category	Details
Incident Type	Data Exfiltration – DNS Tunnelling
Severity	Critical
Priority	Immediate
Detection Sources	DNS Logs, NDR, SIEM, EDR, Firewall Logs, Threat Intel Feeds

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enable DNS logging and retention	Capture query names, source IPs and resolver data
Implement DNS monitoring tools	Use NDR or DNS analytics to detect anomalies
Use domain allow/deny lists	Block known malicious or unused dynamic DNS services
Alert on high-frequency and entropy-based queries	e.g., 50+ DNS requests per minute from a single host
Train analysts on tunnelling patterns	Long subdomains, rare TLDs, base64-like strings

2. Detection & Analysis

Step	Action
Alert triggered	Unusual DNS behaviour detected, e.g., long subdomains, spikes in DNS volume
Identify source host and user	Correlate logs to determine which system is exfiltrating data
Extract and decode suspicious queries	Attempt to reconstruct exfiltrated data or file names
Review endpoint activity	Look for the presence of DNS tunnelling tools or scripts

MITRE ATT&CK mapping	T1071.004 (Application Layer Protocol: DNS), T1048 (Exfiltration Over Alternative Protocol)
----------------------	---

3. Containment

Step	Action
Isolate affected endpoint	Immediately block network access to prevent further leakage
Block suspicious domains and resolvers	At internal DNS servers, firewalls and proxies
Revoke credentials used on the host	If attacker had access to mapped shares or cloud tokens
Notify stakeholders and incident command team	To begin impact assessment

4. Eradication

Step	Action
Remove tunnelling tools or scripts	From the compromised system (e.g., iodine, dnscat2)
Check for persistence mechanisms	Registry keys, startup folders, scheduled tasks
Review for lateral movement	Was the tool used on multiple hosts or installed via script?
Remove DNS resolver modifications	That point to rogue or external DNS infrastructure

5. Recovery

Step	Action
Patch and harden the host	Apply updates and enforce endpoint protection policies
Restore normal DNS configurations	With internal monitoring still enabled
Resume user activity with strict monitoring	Only after validating endpoint integrity
Monitor for reattempts	On both endpoint and network levels

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	Determine how the DNS tunnelling tool was deployed and which controls failed

Refine DNS policies and alerts	Add signatures or detection rules for tunnelling behaviours
Train SOC analysts	On DNS tunnelling detection and response
Share indicators and behaviours	Include domains, tools, hashes and DNS patterns
Notify regulators if data loss is confirmed	Especially if personal or financial information was affected

Tools Typically Involved

- DNS Logging Platforms (e.g., Infoblox, Corelight, Zeek)
- SIEM (e.g., Splunk, Sentinel)
- NDR (e.g., Vectra, Darktrace, ExtraHop)
- EDR (e.g., CrowdStrike, Defender, SentinelOne)
- Firewall and DNS Filtering Tools (e.g., Cisco Umbrella, Palo Alto)
- DNS Tunnel Detection Tools (e.g., Pi-hole with logging, OpenDNS anomaly detection)

Success Metrics

Metric	Target
Time to Detect DNS Tunnelling	<15 minutes from first beacon
Endpoint Isolation Time	<10 minutes from confirmation
Full DNS Rule Update	Within 2 business days
RCA Report and IOC Sharing	Within 3 business days
Re-education of SOC Team	Within 5 business days

SOC Incident Response Playbook 33: Compromise Through Vulnerable Open-Source Components

Scenario

A public-facing or internal web application uses an outdated open-source library or component (e.g., Log4j, Apache Struts, jQuery, Spring Framework) with known vulnerabilities. Attackers exploit the flaw to execute arbitrary code, extract sensitive data or gain access to backend systems.

Incident Classification

Category	Details
Incident Type	Web Application Exploitation – Vulnerable Component
Severity	Critical
Priority	Immediate
Detection Sources	WAF, SIEM, SAST/DAST Scanners, Runtime Protection Tools (RASP), Threat Intel Feeds

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Maintain SBOM (Software Bill of Materials)	For all deployed apps and dependencies
Integrate SCA (Software Composition Analysis)	Tools like Snyk, Dependabot or WhiteSource
Deploy WAF with virtual patching	To block known exploit signatures in HTTP traffic
Subscribe to CVE/KEV feeds	Track zero-day or actively exploited vulnerabilities
Ensure logs capture HTTP headers, payloads and stack traces	For post-exploit analysis

2. Detection & Analysis

Step	Action
Alert triggered	WAF or SIEM detects suspicious request targeting known vulnerable endpoint
Identify vulnerable component	e.g., log4j-core-2.14.1.jar or struts2-core-2.3.x
Analyse exploitation attempt	Review payload (e.g., \${jndi:ldap://...} or OGNL injection)

Cross-reference app version with known CVEs	Confirm exploitability
MITRE ATT&CK mapping	T1190 (Exploit Public-Facing Application), T1210 (Exploitation of Remote Services), T1059 (Command Execution)

3. Containment

Step	Action
Block malicious traffic	At WAF, firewall or reverse proxy layer
Isolate affected application	Temporarily take offline if compromise is confirmed
Rotate credentials or secrets	If stored in the app or environment variables
Notify DevOps and application owners	To begin emergency patching process

4. Eradication

Step	Action
Patch or remove vulnerable component	Upgrade to safe version or disable feature temporarily
Check for webshells or dropped binaries	Look in app server directories and upload paths
Audit application logs and access patterns	Detect suspicious user sessions or command execution
Rebuild application from secure codebase	If necessary, redeploy using CI/CD pipeline with clean dependencies

5. Recovery

Step	Action
Restore application in patched state	Only after full validation and security hardening
Monitor for continued exploit attempts	Maintain elevated alerting during initial days post-patch
Conduct vulnerability scanning	To ensure no other legacy components are exploitable
Resume business service	After full regression and security testing

6. Lessons Learned & Reporting

Step	Action
------	--------

Conduct RCA	Identify how the vulnerable component persisted in production
Update CI/CD pipelines	Integrate dependency scanning and fail builds on critical CVEs
Educate developers	On secure dependency management and avoiding deprecated libraries
Document full incident timeline and IOCs	For audit and legal review
Notify customers or regulators	If sensitive data or service integrity was affected

Tools Typically Involved

- WAF (e.g., Cloudflare, F5, AWS WAF)
- SIEM (e.g., Splunk, Sentinel)
- SCA Tools (e.g., Snyk, Black Duck, OWASP Dependency-Check)
- SAST/DAST (e.g., SonarQube, Burp Suite, Netsparker)
- Runtime Application Protection (RASP)
- Container Scanners (e.g., Trivy, Clair, Aqua Security)

Success Metrics

Metric	Target
Time to Patch Vulnerable Component	<24 hours for known exploit
Time to Block Exploit Attempts	<1 hour via WAF or proxy
Full Log Review of Exploit Window	Completed within 1 business day
CI/CD Pipeline Policy Enforcement	Rolled out within 3 business days
Developer Secure Coding Briefing	Completed within 5 business days

SOC Incident Response Playbook 34: Command and Control via Cloud Storage Platforms

Scenario

An attacker abuses a cloud storage platform (such as Dropbox or Google Drive) to host malware payloads, receive stolen data or exchange instructions with compromised systems. Since traffic to these services is often allowed by default, the attacker evades traditional C2 detection.

Incident Classification

Category	Details
Incident Type	C2 Communication – Cloud Storage Abuse
Severity	High
Priority	High
Detection Sources	Proxy Logs, CASB, SIEM, EDR, NDR, Threat Intel Feeds

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Monitor file uploads/downloads to cloud storage	Use CASB or proxy integrations with DLP and anomaly detection
Deploy threat intel enrichment	Detect access to known malicious shared folders or URLs
Define policies for allowed storage services	Limit access only to business-approved cloud platforms
Set alerts for unusual cloud access patterns	e.g., high volume uploads, downloads or file types
Train users to report suspicious file sharing links	Especially from unverified sources

2. Detection & Analysis

Step	Action
Alert triggered	Unusual cloud traffic (e.g., executable download from public Dropbox link) or unapproved tool access
Identify host and user involved	Correlate download/upload timestamp and destination folder
Inspect downloaded/uploaded file	Run in sandbox or analyse via EDR

Detect beaconing behaviour	Repeated access to the same cloud folder or scheduled uploads
MITRE ATT&CK mapping	T1105 (Ingress Tool Transfer), T1567.002 (Exfiltration to Cloud Storage), T1095 (Non-Application Layer Protocol)

3. Containment

Step	Action
Isolate endpoint showing C2 patterns	Prevent further uploads/downloads or lateral spread
Revoke OAuth/cloud API tokens	If linked to attacker-controlled apps or sessions
Block access to malicious domains or file-sharing links	Using proxy/DNS filters and threat intel lists
Notify affected users and business units	Especially if corporate data was shared or downloaded

4. Eradication

Step	Action
Remove malicious files or tools	From the host and shared cloud locations
Revoke access permissions to cloud shares	Remove public links or externally shared files
Clean up persistence mechanisms	e.g., scripts or scheduled tasks accessing cloud services periodically
Patch exploited vulnerabilities	If malware gained access through app/plugin flaws

5. Recovery

Step	Action
Reconnect systems after clean-up	With monitoring in place for cloud traffic anomalies
Re-enable cloud access where appropriate	Only for vetted users and services
Monitor for reinfection attempts	Or repeated connections to suspicious folders/domains
Resume business operations	With validated logs and cleaned environment

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	Determine how attacker accessed or delivered C2 instructions via cloud

Update CASB and proxy alert rules	Add specific detections for unauthorised cloud usage and file types
Share IOCs and tactics internally	Including URLs, file hashes and domains
Refine cloud access policies	Limit OAuth authorisations and public folder sharing settings
Notify third parties or regulators if data was exfiltrated	Include timeline and response actions

Tools Typically Involved

- CASB (e.g., Microsoft Defender for Cloud Apps, Netskope)
- Proxy & Web Filtering (e.g., Zscaler, Forcepoint, Palo Alto)
- SIEM (e.g., Splunk, Sentinel)
- EDR/XDR (e.g., CrowdStrike, Defender, Cortex XDR)
- NDR (e.g., ExtraHop, Darktrace)
- Threat Intelligence Platforms (e.g., Recorded Future, Anomali)

Success Metrics

Metric	Target
Time to Detect Cloud C2	<30 minutes from first beacon
Endpoint Isolation Time	<15 minutes
Malicious Link/Token Revocation	Within 1 hour
IOC Sharing and Policy Updates	Within 2 business days
RCA and Access Review Completion	Within 3 business days

SOC Incident Response Playbook 35: Persistence Through Malicious Browser Extensions

Scenario

An attacker convinces a user to install a browser extension that appears legitimate (e.g., productivity tools, free PDF converters), but the extension has hidden functionality. It may capture keystrokes, steal session tokens, manipulate browser traffic or serve as a persistent C2 channel.

Incident Classification

Category	Details
Incident Type	Endpoint Compromise – Malicious Browser Extension
Severity	High
Priority	High
Detection Sources	EDR, Browser Logs, SIEM, CASB, User Reports, Endpoint Management Tools

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enforce browser extension policies	Restrict installations via GPO or MDM (e.g., only allowlisted extensions)
Monitor extension inventory	Through endpoint/browser telemetry (e.g., Chrome enterprise reporting)
Block access to unverified extension stores	Using proxy or firewall policies
Train users on browser hygiene	Recognising risky permissions and deceptive extensions
Enable logging of browser extension installs/updates	Through centralised endpoint management

2. Detection & Analysis

Step	Action
Alert triggered	Unknown or flagged browser extension installed by a user
Identify extension ID, name and permissions	Check for access to tabs, cookies, clipboard, etc.
Correlate user activity and logs	Was the extension capturing credentials, sessions or injecting content?

Reverse engineer extension if needed	Analyse code or behaviour using a sandbox or manual inspection
MITRE ATT&CK mapping	T1176 (Browser Extensions), T1056.001 (Input Capture: Keylogging), T1557 (Man-in-the-Middle)

3. Containment

Step	Action
Remotely uninstall the extension	Via MDM or browser enterprise controls
Isolate affected device if compromise is confirmed	Especially if credential theft or token hijacking occurred
Block extension ID via policy or DNS filters	Prevent reinstallation or callback communication
Notify affected user	Prompt password reset and browser profile reauthentication

4. Eradication

Step	Action
Clear browser cache, sessions and stored tokens	Remove persistent cookies or hijacked tokens
Remove associated files or processes	If the extension dropped additional scripts or payloads
Re-image browser profile if necessary	If manipulation or deeper persistence is found
Scan for additional endpoints with same extension	Using EDR or browser telemetry

5. Recovery

Step	Action
Restore browser access with clean profile	And re-authentication using new credentials
Re-enable access to business apps	After validation of identity and device integrity
Resume operations	With enhanced monitoring on the affected user group
Monitor for new extension installs	Flag users bypassing browser security policies

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	How was the extension installed and why wasn't it blocked?

Strengthen extension governance	Define and enforce allowlist/blocklist policies
Share threat intelligence internally	Extension ID, developer email, API endpoints, hashes
Educate users and support teams	On identifying and reporting suspicious browser behaviours
Report to extension store/vendor	If the extension is not already removed from public listing

Tools Typically Involved

- EDR (e.g., CrowdStrike, Defender, SentinelOne)
- Browser Enterprise Policies (e.g., Chrome, Edge, Firefox)
- MDM/Endpoint Management (e.g., Intune, Jamf)
- SIEM (e.g., Splunk, Sentinel)
- DNS & Web Filtering Tools (e.g., Cisco Umbrella, Palo Alto)
- Threat Intel Platforms (for tracking extension campaigns)

Success Metrics

Metric	Target
Extension Removal Time	<30 minutes from detection
Device Isolation Time	<15 minutes if compromise confirmed
IOC Sharing to Team	Within 1 business day
Extension Policy Review and Update	Within 2 business days
User Re-education and Incident Briefing	Within 3 business days

SOC Incident Response Playbook 36: Ransomware via Third-Party Vendor Compromise

Scenario

A trusted third-party vendor (e.g., IT support, software provider, MSP) is compromised. The attacker uses this trust relationship, such as VPN access, RMM tools or supply chain software updates, to deploy ransomware across the environment, encrypting files and demanding payment.

Incident Classification

Category	Details
Incident Type	Ransomware – Supply Chain or Vendor Breach
Severity	Critical
Priority	Immediate
Detection Sources	EDR, SIEM, File Integrity Monitoring, Backup Alerts, Threat Intelligence Feeds

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enforce vendor access segmentation	Use separate, time-limited VPN accounts with MFA
Monitor vendor RMM activity	Record sessions and alert on unusual behaviours
Conduct regular vendor risk assessments	Review security posture and incident history
Isolate backup systems	Ensure backups are offline or immutable
Simulate ransomware scenarios	Test response and restoration procedures

2. Detection & Analysis

Step	Action
Alert triggered	File encryption activity, file renaming patterns or EDR ransomware behaviour detected
Identify source of attack	Trace initial access point to vendor VPN, RMM tool or software update
Inspect ransom notes and filenames	To identify ransomware variant (e.g., LockBit, Black Basta)

Review logs for lateral movement	Check internal spread paths and privilege escalation attempts
MITRE ATT&CK mapping	T1078 (Valid Accounts), T1486 (Data Encrypted for Impact), T1210 (Remote Services Exploitation), T1195 (Supply Chain Compromise)

3. Containment

Step	Action
Disconnect affected systems from the network	Prevent further spread of ransomware
Disable vendor accounts and remote access	Immediately terminate sessions and revoke credentials
Isolate backup infrastructure	Verify if backups are impacted or encrypted
Block known IOCs	File hashes, IPs, C2 domains via firewall, DNS and endpoint controls

4. Eradication

Step	Action
Remove ransomware executables and persistence mechanisms	From all impacted endpoints and servers
Clean or reimage compromised systems	Depending on the extent of damage
Remove malicious vendor scripts or software	That may have been used as a payload
Patch exploited systems	Close any vulnerabilities used during access or privilege escalation

5. Recovery

Step	Action
Restore from known-good backups	After verifying no reinfection or backdoors exist
Resume critical services in phases	Based on validated restoration process
Monitor systems post-restoration	For any residual ransomware or indicators of compromise
Conduct full forensic analysis	While recovery efforts are ongoing

6. Lessons Learned & Reporting

Step	Action
------	--------

Conduct RCA	Determine how the vendor's access was used and what could have been prevented
Review vendor management practices	Strengthen controls around onboarding, access and monitoring
Update incident response and restoration plans	Based on observed weaknesses
Notify impacted parties and regulators	If required by law, compliance or policy (e.g., PDPA, GDPR)
Consider legal or contractual action	If the vendor violated terms or failed to follow security obligations

Tools Typically Involved

- EDR/XDR (e.g., CrowdStrike, SentinelOne, Cortex XDR)
- SIEM (e.g., Splunk, Sentinel)
- Backup & Recovery Platforms (e.g., Veeam, Rubrik)
- RMM Monitoring (e.g., ConnectWise, SolarWinds, AnyDesk)
- Firewall & DNS Filtering (e.g., Fortinet, Zscaler)
- Threat Intel Platforms (e.g., Recorded Future, VirusTotal)

Success Metrics

Metric	Target
Time to Disconnect Infected Hosts	<15 minutes
Vendor Access Termination Time	<10 minutes
Restoration Time for Critical Services	<24–48 hours
RCA Completion & Reporting	Within 5 business days
Vendor Access Review & Revalidation	Within 7 business days

SOC Incident Response Playbook 37: Secrets Leakage Through Public Git Repositories

Scenario

A developer accidentally commits secrets (e.g., AWS keys, database passwords, private keys) to a public Git repository. Attackers scan these platforms for such leaks and may quickly use the credentials for unauthorised access, data exfiltration or lateral movement.

Incident Classification

Category	Details
Incident Type	Credential Exposure – Public Repository
Severity	High
Priority	High
Detection Sources	Git Scanners, SIEM, Bug Bounty Reports, Threat Intel Feeds, Developer Alerts

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Use Git secret scanners pre-commit	e.g., Git hooks with gitleaks, truffleHog, detect-secrets
Implement CI/CD pipeline scanning	Automatically check commits for hardcoded secrets
Monitor public Git platforms	Use tools or services like GitHub Advanced Security, GitGuardian or custom scripts
Educate developers	On secret management, environment variables and .gitignore usage
Enforce secret storage policies	Use vaults like HashiCorp Vault, AWS Secrets Manager

2. Detection & Analysis

Step	Action
Alert triggered	Public repo scan detects exposed secret (e.g., AWS key pattern match)
Identify affected repository and commit	Check whether it's public and accessible to unauthorised users
Validate exposure	Confirm whether the secret is real, active and in use
Check for access logs	Look for recent access using the leaked credentials (cloud audit logs, DB logs)

MITRE ATT&CK mapping	T1552.001 (Credentials in Files), T1210 (Exploitation of Remote Services), T1078 (Valid Accounts)
----------------------	---

3. Containment

Step	Action
Revoke the exposed secret immediately	e.g., deactivate API key, rotate access key, revoke token
Temporarily disable associated service	If the secret has been used maliciously
Remove the secret from history	Use tools like git filter-branch or BFG Repo-Cleaner
Change associated credentials	If passwords or database access details were exposed
Notify security and DevOps teams	So they can begin wider assessment

4. Eradication

Step	Action
Replace affected secrets securely	Use environment variables or secure vaults for redeployment
Delete or archive exposed repositories	If no longer needed or too compromised
Scan entire repository history	To detect any additional secrets in older commits
Block further commits with secrets	Using pre-commit hooks or pipeline checks

5. Recovery

Step	Action
Resume services with new credentials	Validate correct configuration in all environments
Monitor access patterns	Watch for any use of revoked credentials (attempted re-use)
Conduct credential hygiene check	Across all environments associated with affected dev team
Resume normal dev workflows	After all secrets are rotated and systems verified clean

6. Lessons Learned & Reporting

Step	Action
------	--------

Conduct RCA	Why was the secret committed? Were policies bypassed?
Educate developers and DevOps	Share what went wrong and how to avoid in future
Enforce tighter secret scanning	In local and CI environments
Update response procedures	Include Git and version control exposure playbooks in IR plan
Notify affected vendors or clients	If shared secrets or third-party integrations were impacted

Tools Typically Involved

- Git Scanners (e.g., Gitleaks, GitGuardian, truffleHog)
- CI/CD Pipelines (e.g., GitHub Actions, GitLab CI)
- Vaults (e.g., AWS Secrets Manager, Azure Key Vault, HashiCorp Vault)
- Threat Intel & Monitoring Tools (e.g., GitHub Audit Logs, VirusTotal)
- SIEM (e.g., Splunk, Sentinel)
- Git Management Platforms (e.g., GitHub Enterprise, Bitbucket, GitLab)

Success Metrics

Metric	Target
Secret Revocation Time	<30 minutes from discovery
History Cleanup Time	<2 hours
Affected System Recovery	<1 business day
Developer Re-training	Within 3 business days
CI/CD Policy Enforcement	Within 5 business days

SOC Incident Response Playbook 38: Privilege Escalation via Unpatched Endpoint Software

Scenario

An attacker gains initial access to a low-privileged user account on a system. They then exploit an unpatched vulnerability in the local OS (e.g., Windows Print Spooler, kernel drivers) or software (e.g., antivirus agent, third-party tools) to escalate to SYSTEM/root privileges and move laterally across the environment.

Incident Classification

Category	Details
Incident Type	Privilege Escalation – LPE Exploitation
Severity	High
Priority	High
Detection Sources	EDR, SIEM, Vulnerability Scanners, Endpoint Logs, Threat Intelligence Feeds

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Regular vulnerability scanning	Detect LPE vulnerabilities (e.g., CVE-2021-34527 PrintNightmare)
Patch management enforcement	Automate OS and software updates across endpoints
Deploy EDR with LPE exploit detection	Alert on exploit behaviour and suspicious process chains
Maintain software inventory	Know which apps and drivers are installed per host
Implement least privilege enforcement	Prevent users from running unnecessary software or services

2. Detection & Analysis

Step	Action
Alert triggered	EDR detects suspicious child process spawned by low-privilege user or exploit signature
Identify exploited process or DLL	e.g., unusual use of rpcss.dll, splwow64.exe or service binary abuse
Confirm escalation	Look for UID/SID changes, NT AUTHORITY\SYSTEM context or token manipulation

Correlate with known CVE	Match exploit behaviour with known LPE vulnerabilities and assess patch status
MITRE ATT&CK mapping	T1068 (Exploitation for Privilege Escalation), T1134 (Access Token Manipulation), T1543.003 (Windows Service Creation)

3. Containment

Step	Action
Isolate affected endpoint	Block lateral movement and external communication
Suspend suspicious process chains	Using EDR or remote kill commands
Block known exploit indicators	Hashes, file paths or behavioural signatures
Notify IT and security teams	Coordinate patching and validation of similar endpoints

4. Eradication

Step	Action
Patch the exploited software or OS	Apply security updates to fix the LPE flaw
Remove any payloads or persistence mechanisms	Registry keys, scheduled tasks, services or malware
Re-image endpoint if compromise is extensive	Especially in high-assurance environments
Validate system integrity	Run integrity check tools and EDR scans

5. Recovery

Step	Action
Restore system operations	After patching, validation and threat removal
Resume normal user activities	With restrictions re-checked and verified
Monitor endpoint for signs of reinfection or escalation	For at least 72 hours post-recovery
Audit access and permissions	Re-verify local and domain group memberships

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	Identify how long the system was unpatched and why

Review and strengthen patching strategy	Include better reporting and enforcement loops
Update detection use cases	Add exploit technique patterns and post-exploitation alerts
Educate system owners and users	On secure software use and escalation risks
Share IOCs and exploit details internally	Across SOC, IT and DevOps teams

Tools Typically Involved

- EDR/XDR (e.g., CrowdStrike, Defender, SentinelOne)
- SIEM (e.g., Splunk, Sentinel)
- Patch Management (e.g., WSUS, SCCM, Tanium, Automox)
- Vulnerability Scanners (e.g., Tenable, Qualys, Rapid7)
- Threat Intel Feeds (e.g., CISA KEV, Exploit DB)
- Process Monitoring Tools (e.g., Sysmon, Process Hacker)

Success Metrics

Metric	Target
Time to Isolate Endpoint	<15 minutes from detection
Time to Patch Vulnerable Hosts	<24 hours for critical LPEs
Privileged Session Review Completion	Within 1 business day
RCA Documentation & Sharing	Within 3 business days
Endpoint Hardening Update	Within 5 business days

SOC Incident Response Playbook 39: Lateral Movement via Service Account Abuse

Scenario

An attacker who has gained access to one endpoint discovers or captures credentials for a high-privileged service account (e.g., via LSASS dump, credential spraying or cleartext config files). The attacker uses the service account, which often has excessive or unrestricted access, to move laterally across systems or access sensitive resources.

Incident Classification

Category	Details
Incident Type	Lateral Movement – Privileged Account Abuse
Severity	Critical
Priority	Immediate
Detection Sources	SIEM, EDR, AD Logs, Identity Protection Tools, Honeytokens

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Monitor service account behaviour	Use UEBA, baselining and identity analytics
Enforce least privilege on service accounts	No interactive login, limit domain access
Use managed identities or secrets vaults	Avoid embedding credentials in plaintext
Alert on use of service accounts outside normal scope	e.g., logging into user machines or off-hours usage
Deploy decoy credentials/honeytokens	To detect unauthorised use quickly

2. Detection & Analysis

Step	Action
Alert triggered	Unusual use of service account, such as interactive login or access to unrelated systems
Identify the origin system and target	Trace lateral movement path from initial host
Correlate account activity	With known service account profile (systems, time, purpose)
Review process and command logs	Look for PsExec, wmic, RDP sessions or scheduled task abuse

MITRE ATT&CK mapping	T1021.002 (SMB/Windows Admin Shares), T1550 (Use of Stolen Credentials), T1078 (Valid Accounts)
----------------------	---

3. Containment

Step	Action
Disable or rotate credentials of affected service account	If compromise is confirmed or strongly suspected
Isolate involved hosts	Limit further propagation or credential harvesting
Block known malicious IPs or user agents	From firewall, proxy or identity provider
Notify domain administrators	Coordinate AD investigation and credential hygiene checks

4. Eradication

Step	Action
Scan and clean compromised systems	Remove tools, backdoors, persistence mechanisms
Remove unauthorised accounts or group memberships	Review Domain Admin, Server Operators or custom roles
Review and tighten service account privileges	Remove interactive logon, remote desktop, etc.
Check for reused credentials	On other hosts or services that may be affected

5. Recovery

Step	Action
Re-enable service accounts with new credentials	Only after patching and role validation
Monitor post-recovery usage	Especially for the next 7–14 days with tighter alerts
Resume operations	After ensuring endpoints and service account flows are clean and restored securely
Perform password/credential resets	For all accounts linked to the same tier of privilege

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	Determine how the account was exposed and used
Refactor service account strategy	Segment, restrict and monitor them rigorously

Share findings internally	Include team leads, system owners and DevOps
Update detection content	Create custom rules for service account anomaly detection
Audit GPOs and privileged access policies	Implement tiering and segmentation (e.g., Tier 0/1/2)

Tools Typically Involved

- EDR/XDR (e.g., CrowdStrike, Defender, SentinelOne)
- SIEM (e.g., Splunk, Sentinel, LogRhythm)
- Active Directory Monitoring (e.g., Microsoft ATA, BloodHound)
- Identity Protection (e.g., Microsoft Identity Protection, Okta)
- UEBA & Threat Detection (e.g., Exabeam, Vectra)
- Password Vaulting (e.g., CyberArk, HashiCorp Vault)

Success Metrics

Metric	Target
Time to Detect Lateral Service Account Use	<30 minutes
Time to Rotate Compromised Credentials	<1 hour
Endpoint Isolation Time	<15 minutes
AD Review Completion	Within 2 business days
Policy Update and Privilege Audit	Within 5 business days

SOC Incident Response Playbook 40: Initial Access via Phishing with Malicious Macros

Scenario

An employee receives a phishing email with an attachment (e.g., .docm, .xlsm) that contains malicious VBA macros. When enabled, the macro executes scripts (e.g., PowerShell, MSHTA) to download and run malware, establishing initial access or dropping payloads such as Emotet, QakBot or remote access trojans.

Incident Classification

Category	Details
Incident Type	Initial Access – Phishing with Weaponised Attachment
Severity	High
Priority	High
Detection Sources	Email Gateway, EDR, SIEM, Endpoint Alerts, Threat Intel Feeds

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enforce macro restriction policies	Block macros in Office files from the internet (e.g., via GPO or Intune)
Deploy email security filtering	Detect and quarantine suspicious attachments
Train users on phishing awareness	Highlight risks of enabling content/macros
Enable auditing for Office script execution	Log VBA, WMI and PowerShell spawned via Office
Use sandboxing for inbound attachments	Detonate files and analyse behaviour

2. Detection & Analysis

Step	Action
Alert triggered	Email gateway flags a suspicious attachment or EDR detects macro-triggered process
Identify affected user and machine	Locate email recipient and where the macro was executed
Analyse document behaviour	Look for embedded scripts, obfuscated code or C2 connections

Correlate spawned processes	winword.exe → powershell.exe, mshta.exe or network activity
MITRE ATT&CK mapping	T1566.001 (Phishing: Spearphishing Attachment), T1059.001 (PowerShell), T1203 (Exploitation for Client Execution)

3. Containment

Step	Action
Isolate the affected endpoint	Prevent malware from spreading or communicating externally
Revoke user session tokens	If credential theft or token access is suspected
Block file hashes, C2 domains and URLs	In proxy, firewall and EDR systems
Quarantine the email	Remove from other inboxes if multiple users received it
Notify user and IT support	Warn about potential compromise and phishing tactics

4. Eradication

Step	Action
Remove downloaded payloads	From disk, registry and memory using EDR tools
Kill malicious processes and scripts	Using automated or manual response actions
Delete malicious email and related artefacts	Including attachments, dropped files and persistence mechanisms
Check for persistence	Registry autoruns, scheduled tasks, startup folder entries

5. Recovery

Step	Action
Patch system and update definitions	Ensure antivirus and software are fully updated
Reconnect system to the network	Only after full clean-up validation
Monitor for signs of reinfection or delayed payloads	Over next 48–72 hours
Resume user activities with caution	After educating the user and confirming system health

6. Lessons Learned & Reporting

Step	Action
------	--------

Conduct RCA	How did the file bypass detection and what user actions enabled execution?
Update email rules and detection logic	Refine attachment scans and macro signatures
Share IOC and TTP information	Internally and with threat intel sharing communities
Train affected users and departments	On latest phishing techniques and macro evasion tactics
Perform campaign scoping	Check if multiple employees received variations of the same phishing campaign

Tools Typically Involved

- Email Security (e.g., Proofpoint, Mimecast, Microsoft Defender for Office 365)
- EDR/XDR (e.g., CrowdStrike, Defender, Cortex XDR)
- Sandbox Detonation (e.g., Any.Run, Cuckoo Sandbox, Joe Sandbox)
- SIEM (e.g., Splunk, Sentinel)
- DNS/Web Proxy Filtering (e.g., Cisco Umbrella, Zscaler)
- Threat Intel Platforms (e.g., VirusTotal, MISP)

Success Metrics

Metric	Target
Time to Quarantine Malicious Email	<15 minutes from detection
Endpoint Isolation Time	<10 minutes from alert confirmation
Payload Removal & User Notification	Within 1 hour
IOC Sharing & Detection Update	Within 1 business day
Anti-Phishing Training Refresher	Within 3 business days

SOC Incident Response Playbook 41: Cloud Credential Theft from Exposed Configuration Files

Scenario

Cloud credentials (e.g., access keys, client secrets, tokens) are embedded in config files that are accidentally left on exposed file shares, public Git repositories, misconfigured web servers or developer endpoints. Adversaries scan for such exposures, extract credentials and use them to access cloud resources.

Incident Classification

Category	Details
Incident Type	Credential Exposure – Cloud Configuration Files
Severity	Critical
Priority	Immediate
Detection Sources	CASB, SIEM, EDR, DLP, Git Scanners, Threat Intelligence Feeds

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enforce credential storage standards	Use vaults (e.g., AWS Secrets Manager, Azure Key Vault)
Scan code and config files for secrets	Pre-commit hooks, CI/CD scanners (e.g., gitleaks, truffleHog)
Monitor public and internal repositories	Detect accidentally committed cloud credentials
Enable CloudTrail/Activity logs	Track usage of API keys, tokens and service principals
Train developers and DevOps	Avoid hardcoding credentials in files or scripts

2. Detection & Analysis

Step	Action
Alert triggered	Credential pattern (e.g., AWS key format) found in a file or unusual cloud API usage detected
Validate exposure and usage	Confirm if credential is active and whether it has been used
Analyse access patterns	Look for access from suspicious IPs, geographies or services
Identify impacted cloud resources	Buckets, VMs, secrets, billing services, etc.

MITRE ATT&CK mapping	T1552.001 (Credentials in Files), T1078.004 (Cloud Accounts), T1526 (Cloud Service Discovery)
----------------------	---

3. Containment

Step	Action
Revoke exposed keys/tokens immediately	Rotate all exposed credentials and disable the leaked ones
Isolate affected services or accounts	Disable compromised sessions or roles
Block malicious IPs	Using cloud firewall rules and web ACLs
Notify DevOps or cloud teams	Coordinate quick response and recovery

4. Eradication

Step	Action
Remove credentials from all known locations	Repositories, file shares, config folders
Redeploy apps using secure secrets management	Refactor code to pull secrets securely at runtime
Validate all affected cloud resources	Check for backdoors, data theft, unauthorised access
Audit environment for similar exposures	Ensure this is not a recurring misconfiguration

5. Recovery

Step	Action
Resume cloud operations	With all credentials rotated and access logs reviewed
Apply IAM policy hardening	Enforce least privilege and session limits
Monitor cloud account for follow-up activity	Elevated logging for a period post-recovery
Resume developer work	After confirming secure pipeline and config hygiene

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	Understand how/where the config file was exposed
Educate teams involved	Secure coding, deployment and cloud key handling best practices
Enhance secrets detection	Integrate automatic scanning into dev lifecycle

Document full exposure timeline and impact	Include usage logs, attacker IPs and exploited services
Notify third parties or regulators if required	Based on data classification or contractual obligations

Tools Typically Involved

- Git Secrets Scanners (e.g., Gitleaks, truffleHog, GitGuardian)
- Cloud Monitoring & Logging (e.g., AWS CloudTrail, Azure Monitor)
- CASB (e.g., Microsoft Defender for Cloud Apps, Netskope)
- SIEM (e.g., Splunk, Sentinel)
- Secret Management (e.g., HashiCorp Vault, AWS Secrets Manager)
- Endpoint Detection (e.g., Defender, CrowdStrike, SentinelOne)

Success Metrics

Metric	Target
Time to Revoke Exposed Credential	<30 minutes
Full Credential Rotation	<4 hours
IOC Review & Detection Rule Update	Within 1 business day
Developer Awareness Briefing	Within 3 business days
Secure Refactoring of Code/Configs	Within 5 business days

SOC Incident Response Playbook 42: Data Exfiltration via Misconfigured S3 Buckets

Scenario

A storage bucket (e.g., Amazon S3) is accidentally made public or has overly permissive access (e.g., Everyone:Read or AuthenticatedUsers:Write). Attackers identify and access the bucket using tools like Shodan or custom scripts, downloading sensitive data or uploading malicious files.

Incident Classification

Category	Details
Incident Type	Data Exfiltration – Cloud Storage Misconfiguration
Severity	Critical
Priority	Immediate
Detection Sources	CSPM Tools, CloudTrail Logs, SIEM, Threat Intelligence, Public Scanners

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enforce least privilege bucket policies	Limit access to specific IAM users/roles
Implement bucket policy validation tools	e.g., AWS Config Rules, AWS Trusted Advisor
Enable logging and versioning	Use CloudTrail and S3 server access logs
Scan for exposed buckets	Using CSPM platforms and third-party tools (e.g., ScoutSuite, Prowler)
Tag and classify sensitive data	Use data classification and DLP tagging

2. Detection & Analysis

Step	Action
Alert triggered	Unusual public access or detection of bucket in public scan
Identify exposed bucket and permissions	Confirm public access, write permissions and data at risk
Correlate with access logs	Identify who accessed what and from where
Analyse data sensitivity	Identify type of information exposed (e.g., PII, credentials, logs)

MITRE ATT&CK mapping	T1537 (Transfer Data to Cloud Account), T1567.002 (Exfiltration to Cloud Storage), T1195 (Supply Chain Compromise)
----------------------	--

3. Containment

Step	Action
Immediately restrict or revoke public access	Change bucket ACLs and block public policies
Enable S3 Block Public Access settings	Globally or per-bucket as appropriate
Disable all anonymous and write access	Until reviewed and approved
Notify cloud administrators and stakeholders	Inform affected data owners

4. Eradication

Step	Action
Audit contents of the bucket	Remove sensitive or unauthorised files
Rotate credentials and secrets found in files	If secrets were exposed in configuration or code
Review bucket lifecycle policies	Prevent data leaks via logs or archived files
Patch automation scripts or IaC templates	To avoid repeat misconfigurations

5. Recovery

Step	Action
Reconfigure and validate bucket access	Confirm only authorised users/roles have access
Re-enable necessary functions securely	Apply fine-grained IAM permissions
Restore safe versions if overwritten or deleted	Use versioning and backup data
Monitor bucket access logs	For any follow-up or brute-force access attempts

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	Determine how and why the bucket was misconfigured
Improve DevOps and IaC validation	Integrate checks into CI/CD pipeline (e.g., Terraform with tfsec)

Create alerting for risky permissions	e.g., s3:ListBucket, s3:GetObject from unknown IPs
Share IOCs and impacted data info internally	Include exact files accessed, size, timestamps
Notify affected parties or regulators	Based on jurisdiction (e.g., GDPR, PDPA, HIPAA)

Tools Typically Involved

- CSPM (e.g., Wiz, Prisma Cloud, AWS Config)
- Cloud Logging (e.g., CloudTrail, S3 Server Access Logs)
- SIEM (e.g., Splunk, Sentinel)
- DLP & Data Classification (e.g., Microsoft Purview, Symantec DLP)
- Threat Intelligence (e.g., GreyNoise, VirusTotal, Recorded Future)
- Infrastructure as Code (e.g., Terraform, CloudFormation with security checks)

Success Metrics

Metric	Target
Time to Block Public Bucket Access	<15 minutes from detection
Incident Notification Time	Within 1 hour
Data Access Review Completion	Within 1 business day
RCA and Policy Update	Within 3 business days
CI/CD Pipeline Security Hardening	Within 5 business days

SOC Incident Response Playbook 43: Unauthorised VPN Access from Reused Credentials

Scenario

An attacker gains valid credentials for a corporate VPN (e.g., via data breach, credential stuffing, phishing or reused passwords). They authenticate successfully and pivot into internal systems. Since no malware is involved initially, the activity may look like normal user behaviour unless deeper analysis is performed.

Incident Classification

Category	Details
Incident Type	Unauthorised Access – Credential Misuse
Severity	High
Priority	Immediate
Detection Sources	VPN Logs, SIEM, Identity Protection, UEBA, EDR, MFA Alerts

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enforce MFA for all remote access	Ensure VPN logins require 2FA
Monitor login behaviour	UEBA for geo-velocity, login time anomalies, unknown IPs
Password policy enforcement	Require strong, unique passwords and periodic rotation
Integrate VPN logs with SIEM	For real-time alerting and correlation
Conduct breach monitoring	Look for leaked credentials in the dark web or paste sites

2. Detection & Analysis

Step	Action
Alert triggered	Login from suspicious geography, new device or bypassed MFA
Review VPN logs and SIEM correlation	Identify login time, IP, user agent and authentication source
Analyse access patterns post-login	Review file access, internal movement, command execution
Validate user action	Contact user to verify login and deny if unauthorised

MITRE ATT&CK mapping	T1078 (Valid Accounts), T1133 (External Remote Services), T1071.001 (Application Layer Protocol: Web Protocols)
----------------------	---

3. Containment

Step	Action
Disable the affected account	Block further access immediately
Invalidate VPN session/token	Revoke the active session if supported by VPN solution
Force credential reset	For the user and any other accounts with reused passwords
Block IP or user agent involved in login	At firewall/VPN gateway if feasible
Notify user and IT support	Immediate alert and further device isolation if needed

4. Eradication

Step	Action
Scan user endpoint(s)	Check for malware, keyloggers or signs of deeper compromise
Audit recent activity	Identify what systems, data or services were accessed
Investigate lateral movement or privilege escalation	Through AD logs, EDR and internal network telemetry
Apply geo-blocking or login restrictions	Based on corporate policy and location expectations

5. Recovery

Step	Action
Re-enable account with new credentials	Only after confirming user identity and device safety
Resume VPN access	With enforced MFA and monitored login activity
Monitor for repeated login attempts	From similar IPs or attacker infrastructure
Resume normal operations	Post-verification and clean-up

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	Identify how credentials were exposed (reuse, breach, phishing)

Improve credential hygiene practices	Enforce SSO, password managers and training
Implement anomaly-based alerting	To detect future valid credential misuse faster
Update playbooks and runbooks	With this scenario and specific TTPs used
Share findings internally	And with threat intel communities if applicable

Tools Typically Involved

- VPN Logs & Management (e.g., Cisco AnyConnect, Palo Alto GlobalProtect, Fortinet)
- SIEM (e.g., Splunk, Sentinel)
- Identity Protection (e.g., Azure AD Identity Protection, Okta)
- EDR/XDR (e.g., CrowdStrike, SentinelOne)
- UEBA (e.g., Exabeam, Vectra)
- Threat Intelligence Monitoring (e.g., Have I Been Pwned, SpyCloud)

Success Metrics

Metric	Target
Time to Disable Compromised Account	<15 minutes from detection
Credential Reset Completion	<1 hour
Full Access Review	Within 1 business day
User & SOC Team Notification	Within 1 hour
Preventive Controls Update	Within 3 business days

SOC Incident Response Playbook 44: Initial Access via Rogue IoT Devices

Scenario

An attacker gains access to the internal network by connecting a rogue IoT device to a corporate LAN port (e.g., via lobby, meeting room or misconfigured VLAN). The device either acts as a passive listener or is used to scan, pivot or launch attacks within the network.

Incident Classification

Category	Details
Incident Type	Physical Access & Network Intrusion via Rogue IoT
Severity	High
Priority	Immediate
Detection Sources	NAC, SIEM, Network Logs, Asset Discovery Tools, NDR

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Implement Network Access Control (NAC)	Only authorised MACs and devices can join
Use 802.1X authentication	Enforce certificate-based network access
Monitor network for unknown MACs	Alert on new, unapproved devices
Maintain asset inventory	Compare live network assets against baseline
Segment IoT devices from internal network	Use VLANs and firewalls to isolate all IoT components

2. Detection & Analysis

Step	Action
Alert triggered	New/unknown MAC address detected on internal LAN
Identify device characteristics	MAC vendor lookup, OS fingerprinting, port scan profile
Determine location of connection	Trace switch port or wireless AP used
Monitor device activity	DNS queries, port scans, ARP probes, data exfiltration attempts
MITRE ATT&CK mapping	T1200 (Hardware Additions), T1046 (Network Service Scanning), T1071 (Application Layer Protocol)

3. Containment

Step	Action
Disconnect the rogue device physically or via switch	Use NAC, port disablement or EDR isolation
Block MAC address at NAC/firewall level	Prevent further access from the same hardware
Quarantine VLAN if automated	Redirect device to isolated zone for analysis
Notify physical security or facilities team	If access point is in sensitive or guest location

4. Eradication

Step	Action
Inspect the rogue device (if recovered)	Identify owner, usage and software running
Conduct forensics	Examine logs for lateral movement or data access attempts
Validate switch/router configurations	Ensure no unauthorised ports are enabled or open
Remove persistence if deployed	Look for rogue DHCP servers, ARP spoofing or malicious DNS settings

5. Recovery

Step	Action
Re-enable affected ports or services	After full investigation and validation
Resume normal traffic flows	Post containment and segmentation checks
Enhance device monitoring rules	Add device fingerprint or behaviour profile to detection stack
Monitor closely for follow-up activity	Internal scanning, new device joins or beaconing

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	Identify how and why the rogue device bypassed controls
Update NAC and asset policies	Enforce stricter access control and device classification
Train staff and physical security	Recognise threats from devices left unattended

Document incident and impact	Include logs, timelines and MAC/IP relationships
Add rules to detect similar anomalies	e.g., scan patterns, beacon intervals or IoT OS strings

Tools Typically Involved

- NAC Solutions (e.g., Cisco ISE, Aruba ClearPass)
- SIEM (e.g., Splunk, Sentinel)
- NDR (e.g., Darktrace, Vectra, Corelight)
- Asset Discovery (e.g., Qualys Asset Inventory, Lansweeper)
- Switch and Router Logs (e.g., Cisco, Juniper)
- EDR (if installed on adjacent endpoints)

Success Metrics

Metric	Target
Time to Disconnect Rogue Device	<10 minutes from detection
Endpoint & VLAN Validation	<2 hours
MAC/IP Forensics Report	Within 1 business day
NAC Policy Review Completion	Within 3 business days
Awareness Training Deployment	Within 5 business days

SOC Incident Response Playbook 45: Unauthorised Cloud Admin Role Escalation

Scenario

An attacker starts with valid credentials or low-privileged access and exploits overly permissive IAM roles, chained role assumptions, misconfigured policies or stolen OAuth/cloud tokens to escalate to a high-privilege role (e.g., AdministratorAccess, Owner, Global Admin). This grants full control of cloud infrastructure and services.

Incident Classification

Category	Details
Incident Type	Cloud Privilege Escalation
Severity	Critical
Priority	Immediate
Detection Sources	Cloud Audit Logs (e.g., AWS CloudTrail, Azure AD Logs), SIEM, CSPM, Identity Protection Tools

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Implement least privilege IAM policies	Avoid wildcard actions and over-broad permissions
Monitor cloud role assumption activity	Alert on unusual or chained role usage
Enforce MFA for all admin-level access	Include support for conditional access policies
Audit and reduce stale roles	Disable unused, legacy or shadow admin accounts
Integrate audit logs into SIEM	Continuously ingest CloudTrail, Azure AD logs, GCP IAM logs

2. Detection & Analysis

Step	Action
Alert triggered	Admin role assumed by unexpected user or from new location/IP
Review recent login and role activity	Trace API calls, role assumption chains and permission changes
Confirm if escalation was legitimate	Cross-check user identity, location and session token details

Analyse actions taken by escalated role	e.g., snapshot creation, user deletion, security group modification
MITRE ATT&CK mapping	T1078.004 (Valid Accounts: Cloud Accounts), T1078 (Privilege Escalation), T1087.004 (Account Discovery: Cloud Account)

3. Containment

Step	Action
Revoke access tokens and sessions	Force re-authentication or session invalidation for the account
Disable or lock impacted accounts	Including any compromised or misused service principals
Remove elevated role bindings	Roll back IAM policy changes or remove role assumption rights
Isolate cloud resources at risk	e.g., restrict access to S3 buckets, storage or admin interfaces
Notify cloud operations and IAM team	Initiate urgent review of role structure and identity usage

4. Eradication

Step	Action
Audit for persistence mechanisms	Look for new roles, tokens, apps or permission grants added post-escalation
Remove malicious/unauthorised roles	Delete any shadow admin or backdoor accounts created
Rebuild compromised credentials or services	Rotate IAM access keys, API tokens and service account credentials
Validate IAM policy structure	Use CSPM or policy analysis tools to check for escalation paths

5. Recovery

Step	Action
Re-enable services with reviewed permissions	After validating access paths and hardening roles
Monitor IAM activities post-restoration	For unusual actions from restored accounts
Resume normal operations	With updated access controls and verified users only
Continue alerting on elevated access	Set temporary heightened logging for sensitive roles

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	Identify initial access vector, escalation path and prevention gaps
Harden IAM policies and review role hierarchy	Implement SCPs, conditional access and explicit deny
Enhance detection rules for cloud privilege anomalies	Include role chaining, session duration abuse and unusual user agents
Train cloud and security teams	On IAM policy creation, abuse patterns and escalation vectors
Share IOC and affected role information	Internally and via threat intel channels if applicable

Tools Typically Involved

- Cloud IAM and Logging (e.g., AWS CloudTrail, Azure AD Sign-In Logs, GCP Admin Activity Logs)
- CSPM Tools (e.g., Prisma Cloud, Wiz, Microsoft Defender for Cloud)
- SIEM (e.g., Splunk, Sentinel)
- Identity & Access Management (e.g., Okta, Azure AD, AWS IAM Analyzer)
- EDR/XDR (on endpoints involved in token access or lateral movement)
- Threat Intelligence Platforms (e.g., MISP, Recorded Future)

Success Metrics

Metric	Target
Role Revocation and Session Kill Time	<15 minutes from detection
IAM Policy Review and Cleanup	Within 1 business day
RCA and Access Re-certification	Within 3 business days
Cloud Environment Hardening Actions	Within 5 business days
SOC Detection Content Update	Within 2 business days

SOC Incident Response Playbook 46: Data Exfiltration via Cloud Sync Abuse

Scenario

An insider or compromised user syncs sensitive corporate data to a personal or unauthorised cloud storage account using tools like OneDrive, Dropbox or Google Drive. This may bypass traditional network DLP solutions and often occurs over legitimate SSL traffic, making detection difficult.

Incident Classification

Category	Details
Incident Type	Data Exfiltration – Cloud Storage Abuse
Severity	High
Priority	High
Detection Sources	CASB, DLP, EDR, Proxy Logs, SIEM, UEBA

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enforce cloud access policies	Use CASB to control access to personal cloud storage services
Monitor sync client installations	Detect unauthorised sync clients on endpoints
Enable content inspection for cloud uploads	Use proxy or firewall DLP capabilities
Classify sensitive data	Tag data for monitoring (e.g., PII, financial, IP)
Implement usage alerts	Flag large or unusual data uploads, especially outside business hours

2. Detection & Analysis

Step	Action
Alert triggered	Unusual upload activity to cloud storage detected by CASB, DLP or proxy
Correlate user identity and device	Match upload activity with endpoint and user
Analyse uploaded data volume and type	Confirm if sensitive documents were exfiltrated
Review sync client usage	Check installation method and user activity logs
MITRE ATT&CK mapping	T1537 (Transfer Data to Cloud Account), T1567 (Exfiltration over Web Services)

3. Containment

Step	Action
Block access to personal cloud storage	Via CASB, proxy or firewall policies
Suspend user access if malicious intent is suspected	Prevent further exfiltration
Isolate affected endpoint	If it was used as the sync source
Notify insider threat or HR team	If user-based violation is involved

4. Eradication

Step	Action
Remove unauthorised cloud sync clients	Via endpoint management tools
Delete local sync folders and logs	After preserving forensic evidence
Investigate whether sensitive data was shared externally	Look at sharing settings within the cloud account (if accessible)
Rotate credentials or reset access	If tokens or session cookies were involved

5. Recovery

Step	Action
Re-authorise user access (if legitimate)	Only after policy confirmation and user clearance
Restore endpoint monitoring	Ensure sync clients are blocked and DLP is functional
Reinforce policies for data transfer	Update acceptable use and cloud access SOPs
Resume normal business operations	After verifying endpoint integrity and user compliance

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	Determine why upload activity wasn't blocked or flagged earlier
Improve cloud visibility and enforcement	Tighten CASB policies and user activity tracking
Update DLP signatures and thresholds	Tune for specific data categories (e.g., spreadsheets with PII)
Deliver user awareness training	On cloud usage and data protection responsibilities
Document and report findings	Include who, what, when, how and preventive measures

Tools Typically Involved

- CASB (e.g., Microsoft Defender for Cloud Apps, Netskope, McAfee MVISION Cloud)
- DLP (e.g., Symantec DLP, Microsoft Purview DLP)
- EDR (e.g., CrowdStrike, SentinelOne, Defender for Endpoint)
- SIEM (e.g., Splunk, Azure Sentinel)
- Proxy/Firewall Logs (e.g., Zscaler, Forcepoint)
- UEBA Tools (e.g., Exabeam, Securonix)

Success Metrics

Metric	Target
Time to Block Exfiltration Channel	<15 minutes from detection
Endpoint Isolation Time	<30 minutes
User Notification & Access Review	Within 1 business day
RCA and Policy Updates	Within 3 business days
DLP & CASB Tuning Completion	Within 5 business days

SOC Incident Response Playbook 47: Initial Access via OAuth Token Abuse (Browser Session Hijacking)

Scenario

An attacker gains access to a valid OAuth token (e.g., from Google, Microsoft, Okta) by stealing a browser session cookie via phishing, malware or man-in-the-browser attacks. The attacker then uses the stolen token to authenticate without triggering MFA, appearing as the legitimate user.

Incident Classification

Category	Details
Incident Type	Credential Misuse – OAuth Token Theft
Severity	High
Priority	Immediate
Detection Sources	Identity Provider Logs, SIEM, UEBA, EDR, CASB

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enforce short token lifetimes	Reduce session persistence duration
Enable conditional access policies	Restrict risky login scenarios (e.g., from unmanaged devices)
Monitor login patterns	Geo-velocity, impossible travel and browser fingerprinting
Integrate IdP logs with SIEM	Ensure login metadata is ingested and alertable
Educate users	On phishing, session hijacking and suspicious browser prompts

2. Detection & Analysis

Step	Action
Alert triggered	Login from unfamiliar device/IP with no MFA challenge
Check session attributes	Browser fingerprint, IP address, device type, token source
Review recent user activity	Look for signs of compromise: inbox rules, data access, privilege changes
Identify token issuance and usage path	Was the token issued via phishing, malware or malicious app?

MITRE ATT&CK mapping	T1550.001 (Use Alternate Authentication Material: Web Session Cookie), T1528 (Steal Application Access Token)
----------------------	---

3. Containment

Step	Action
Revoke OAuth sessions and tokens	In IdP (e.g., Microsoft Entra ID, Okta, Google Workspace)
Force logout and MFA re-authentication	Across all user sessions
Suspend user access temporarily	Until endpoint and session are validated
Block suspicious IPs and devices	In identity provider and firewall/proxy systems

4. Eradication

Step	Action
Scan the user's endpoint	Look for stealers, token grabbers, browser malware
Remove malicious extensions	If browser-based hijack was used
Review API and application authorisations	Remove unauthorised third-party OAuth apps
Change user credentials and reset MFA methods	If attacker attempted MFA takeover

5. Recovery

Step	Action
Re-enable user account	After confirming endpoint and session are clean
Monitor session re-authentication logs	Watch for reuse of previously stolen cookies
Reinforce browser session protections	Enforce re-authentication after IP/device changes
Resume normal business functions	With heightened monitoring

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	Determine how the token was stolen (e.g., phishing page, malware)
Harden access policies	Enable sign-in risk detection and session behaviour analytics
Train user and team on safe browser practices	Avoid reusing sessions across devices or networks

Add alerting for similar login patterns	e.g., token reuse, mismatched device profile, user-agent anomalies
Report if required	Based on breach severity or regulatory obligations (e.g., PDPA, GDPR)

Tools Typically Involved

- Identity Provider (e.g., Microsoft Entra ID, Okta, Google Workspace)
- SIEM (e.g., Splunk, Sentinel)
- UEBA (e.g., Exabeam, Securonix)
- CASB (e.g., Microsoft Defender for Cloud Apps, Netskope)
- Endpoint Protection (e.g., Defender, CrowdStrike, SentinelOne)
- Threat Intel (e.g., MISP, Recorded Future)

Success Metrics

Metric	Target
Session Revocation Time	<15 minutes from detection
Credential and MFA Reset Completion	Within 1 hour
Endpoint Clean-up & Validation	Within 1 business day
Policy Hardening & Alert Update	Within 3 business days
Awareness Training Follow-Up	Within 5 business days

SOC Incident Response Playbook 48: Persistence via Cloud Workload Implants

Scenario

An attacker gains initial access to a cloud environment and implants persistent code into serverless services (e.g., AWS Lambda, Azure Functions, GCP Cloud Functions). These implants may execute commands, beacon outbound, exfiltrate data or re-establish access.

Incident Classification

Category	Details
Incident Type	Persistence – Cloud Workload Tampering
Severity	High
Priority	Immediate
Detection Sources	Cloud Audit Logs, CSPM, SIEM, EDR (cloud agent), Source Code Repo Logs

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enforce IaC (Infrastructure as Code) deployment	All functions must originate from source-controlled templates
Enable audit logging for all serverless activities	CloudTrail (AWS), Activity Logs (Azure), Audit Logs (GCP)
Use code signing or integrity checks	To prevent tampering with deployed functions
Implement strict IAM roles	Least privilege for function creation and modification
Deploy CSPM rules	Alert on unapproved function creation, update or invocation patterns

2. Detection & Analysis

Step	Action
Alert triggered	Unusual serverless function created or modified outside CI/CD
Identify function origin	Check deployment timestamp, user, role, IP address, source code hash
Analyse function payload	Reverse engineered code or configuration, detect obfuscated logic

Review invocation patterns	Look for beaconing, data exfiltration, command-and-control behaviour
MITRE ATT&CK mapping	T1059 (Command and Scripting Interpreter), T1546.008 (Implant in Startup Items or Scheduled Tasks), T1203 (Exploitation for Client Execution – cloud variant)

3. Containment

Step	Action
Disable or delete the rogue function	Immediately stop execution of the implant
Revoke associated IAM roles or keys	Limit attacker's cloud-level permissions
Freeze modification of critical services	Temporary read-only lock on affected workloads or regions
Notify cloud engineering and SOC teams	Coordinate rapid response and validation of other workloads

4. Eradication

Step	Action
Remove all unauthorised functions or code	Validate each against known CI/CD signatures or hashes
Rotate all keys and tokens used in impacted services	Especially if leaked from the implant's logic
Conduct repo audit	Check for poisoned IaC templates or modified deployment pipelines
Restore functions from trusted source	Redeploy from clean backups or source-controlled templates

5. Recovery

Step	Action
Re-enable legitimate functions	After validation and review of runtime environment
Resume CI/CD operations with integrity checks	Require code signing or integrity monitoring on future deployments
Monitor invocation metrics	Validate against baseline behaviour for anomalies post-restoration
Resume business processes	Once confirmed that no backdoors or misconfigurations remain

6. Lessons Learned & Reporting

Step	Action
Conduct RCA	Identify how the attacker implanted the function (API keys, console access, CI/CD hijack)
Improve alerting for workload changes	Include real-time notifications for serverless deployment actions
Enforce workload access reviews	Periodic review of IAM roles and permissions tied to serverless
Deliver security training to developers	On secure serverless practices and change control processes
Document and share findings	Internally and (if applicable) with threat intel feeds

Tools Typically Involved

- Cloud Logs (e.g., AWS CloudTrail, Azure Activity Logs)
- CSPM (e.g., Wiz, Prisma Cloud, Microsoft Defender for Cloud)
- SIEM (e.g., Splunk, Sentinel)
- CI/CD Pipeline Integrations (e.g., GitHub Actions, Jenkins, GitLab CI)
- Code Analysis Tools (e.g., SonarQube, Snyk)
- Threat Detection in Cloud Functions (e.g., Datadog, AWS GuardDuty)

Success Metrics

Metric	Target
Time to Disable Rogue Function	<10 minutes from detection
IAM Role Revocation Time	<1 hour
Full Code and Invocation Audit Completion	Within 1 business day
CI/CD Remediation and Lockdown	Within 3 business days
SOC Detection Rule Update	Within 2 business days

SOC Incident Response Playbook 49: Command-and-Control via Trusted Third-Party APIs

Scenario

An attacker avoids traditional C2 infrastructure by using trusted, widely allowed APIs or platforms (e.g., Slack webhooks, Dropbox uploads, Telegram bots, Google Sheets) to issue commands, exfiltrate data or receive execution results. These communications often blend into normal outbound traffic and are difficult to detect.

Incident Classification

Category	Details
Incident Type	Command and Control – API Abuse
Severity	High
Priority	High
Detection Sources	EDR, NDR, Proxy Logs, SIEM, Threat Intelligence Feeds

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Restrict access to known risky API endpoints	Block platforms like Pastebin, Discord, Telegram on corporate networks
Enable TLS inspection for outbound traffic	To detect anomalies in encrypted flows
Monitor unusual HTTP/HTTPS destinations	Especially to API subdomains or known C2-abused services
Build behavioural baselines	For normal use of cloud-based APIs (e.g., Slack, Google Drive)
Integrate with threat intelligence	Maintain updated IOCs for abused third-party platforms

2. Detection & Analysis

Step	Action
Alert triggered	Endpoint reaching out to non-corporate API services at odd hours or with beacon-like patterns
Investigate destination	Identify service (e.g., Dropbox API, Telegram bot domain), check domain reputation
Review payload and traffic size	Look for repetitive patterns, encoded content or timed intervals

Inspect EDR logs	Identify parent processes that initiated connections to API endpoints
MITRE ATT&CK mapping	T1102.002 (Web Service: Bidirectional Communication), T1071.001 (Application Layer Protocol: Web Protocols)

3. Containment

Step	Action
Block outbound access to the abused API endpoint	Via proxy, firewall or DNS sinkhole
Isolate infected host(s)	Stop ongoing C2 activity and lateral movement attempts
Revoke API tokens or keys if attacker used a legitimate service	E.g., Slack tokens, Telegram bot tokens
Notify SOC and incident team	Coordinate on further forensic actions

4. Eradication

Step	Action
Remove malware or scripts leveraging APIs	Use EDR to detect persistence mechanisms (e.g., autoruns, scheduled tasks)
Hunt for similar connections across fleet	Search by domain, port, user-agent and IP
Inspect for data exfiltration	Review upload activity to services like Dropbox, Google Drive, etc.
Clean registry or configuration artifacts	Remove scripts or batch files referencing API endpoints

5. Recovery

Step	Action
Restore endpoint functionality	After full malware clean-up and monitoring enablement
Validate outbound traffic	Confirm no further attempts to contact similar services
Reinforce perimeter control	Add abused domains to blocked lists or risky API usage policies
Resume operations	After endpoint is cleared and C2 activity is no longer present

6. Lessons Learned & Reporting

Step	Action
------	--------

Conduct RCA	How the API-based C2 was established and persisted
Update network and SIEM detection rules	For API-based command delivery patterns and obfuscated traffic
Enforce least privilege on allowed apps	Whitelist only business-critical API services
Train users and developers	On risks of using public APIs or webhooks without controls
Document incident thoroughly	Including time of connection, tools used and attacker objectives

Tools Typically Involved

- EDR (e.g., SentinelOne, CrowdStrike)
- NDR (e.g., Darktrace, Corelight, ExtraHop)
- Proxy Logs (e.g., Zscaler, Palo Alto)
- DNS Logging and Filtering (e.g., Cisco Umbrella)
- SIEM (e.g., Splunk, Sentinel)
- Threat Intelligence Platforms (e.g., VirusTotal, AbuseIPDB, MISP)

Success Metrics

Metric	Target
Time to Block C2 API Endpoint	<15 minutes from detection
Host Isolation Time	<30 minutes
IOC Propagation to Security Stack	<1 hour
C2 Technique Detection Rule Deployment	Within 2 business days
Full Incident Documentation and RCA	Within 3 business days

SOC Incident Response Playbook 50: Privilege Escalation Through SaaS Misconfigurations

Scenario

An attacker or insider exploits misconfigured SaaS application settings, such as over-permissioned third-party apps, improperly delegated admin rights or overly broad sharing policies, to gain unauthorised access or escalate privileges to sensitive data and functions.

Incident Classification

Category	Details
Incident Type	Misconfiguration – SaaS Privilege Escalation
Severity	High
Priority	Immediate
Detection Sources	SaaS Security Tools (SSPM/CSPM), SIEM, Identity Logs, CASB, Admin Audit Logs

Phases and Actions

1. Preparation (Pre-Incident Setup)

Task	Tool/Action
Enforce least-privilege model	Limit SaaS admin roles strictly to required personnel
Conduct periodic access reviews	Especially on third-party app permissions and delegated roles
Monitor SaaS configurations continuously	Use SSPM or CASB tools with drift detection
Ingest SaaS logs into SIEM	Include login events, role changes, app grants and sharing updates
Set alerting for sensitive role assignments	e.g., Global Admin, Super Admin, Owner roles

2. Detection & Analysis

Step	Action
Alert triggered	Unexpected admin role granted, third-party app with excessive scopes approved
Investigate actor	Validate the user or app that received new privileges
Review audit logs	Focus on who assigned roles, when, from where and what privileges were escalated

Inspect related activities	e.g., mailbox access, data downloads, permission changes, external sharing
MITRE ATT&CK mapping	T1068 (Exploitation for Privilege Escalation), T1078.004 (Valid Accounts: Cloud), T1548.003 (Abuse Elevation Control Mechanism: Sudo and Admin Roles)

3. Containment

Step	Action
Revoke elevated roles or app permissions	Remove Global Admin, API tokens or excessive OAuth scopes
Suspend suspicious user/app account	If found to be malicious or unauthorised
Block external access if needed	Based on IP, location or app signature
Notify stakeholders	Especially cloud, IAM and legal/HR teams if insider risk is suspected

4. Eradication

Step	Action
Reset affected configurations	Restore default roles, disable risky sharing or integrations
Audit for persistent access vectors	Such as app registration, service accounts or API keys left behind
Validate integrity of settings	Confirm no other privilege escalation paths exist in the environment
Rotate credentials	For any affected admin accounts or apps

5. Recovery

Step	Action
Restore legitimate access only	After re-certification of user roles and app scopes
Re-enable suspended users/app if validated	Under revised security policies
Monitor high-privilege actions	Temporarily increase alerting for admin activity logs
Resume normal SaaS operations	Once environment is secured and verified

6. Lessons Learned & Reporting

Step	Action
------	--------

Conduct RCA	Determine the root of misconfiguration, user error, default settings or poor controls
Review and tighten SaaS admin policies	Especially for integrations and shared drives/folders
Update detection rules	For unusual role assignments or third-party app grants
Educate SaaS admins and users	On least-privilege access, app approval process and safe sharing
Document and report findings	Internally and externally if breach thresholds are met

Tools Typically Involved

- SSPM/CSPM (e.g., AppOmni, Adaptive Shield, Wiz, Microsoft Defender for Cloud Apps)
- Identity Protection (e.g., Okta, Azure AD)
- SIEM (e.g., Splunk, Sentinel, Elastic)
- CASB (e.g., Netskope, Symantec, Microsoft Defender for Cloud Apps)
- Admin Audit Logs (e.g., M365 Unified Audit Logs, Google Workspace Admin Reports)
- SaaS APIs & Admin Consoles (for validation and enforcement)

Success Metrics

Metric	Target
Role/App Permission Revocation Time	<15 minutes from detection
Full Privilege Audit Completion	Within 1 business day
RCA and Policy Review	Within 3 business days
Detection Rules & Automation Update	Within 2 business days
Admin Training Completion	Within 5 business days